كورس تأسيسي عملي للمبتدئين والخريجين

كيف تبدأ في GRC

الحوكمة والمخاطر والامتثال من الصفر: تفهم العمل، وتطبّقه على شركة واحدة، ثم تجهز ملفك للوظيفة الأولى.

8 وحدات | حالة عملية واحدة | 4 تطبيقات موجهة | كراسة تمارين وإجابات

G الحوكمة
من يقرر، وبأي قواعد

R المخاطر
ما الذي قد يحدث، وماذا نفعل

C الامتثال
هل نلتزم، وكيف نثبت

ماذا ستستطيع أن تفعل بعد هذا الكورس؟

بعد الكورس ستستطيع أن:

1. تفهم طبيعة العمل في GRC وأدواره اليومية.
2. تميّز بين الحوكمة والمخاطر والامتثال بمثال.
3. تنفّذ مهام تأسيسية صغيرة: مسؤوليات، وخطر، وتقييم ضابط، وملاحظة.
4. تختار شهادتك ومسارك التعليمي حسب هدفك ومرحلتك.
5. تجهز ملف أعمال وسيرة ولينكدإن، وتستعد للمقابلة.

ما لا يقدمه الكورس

⚠ تأهيلاً كاملاً لإدارة برنامج GRC.

⚠ تطبيق ECC كاملاً في جهة حقيقية.

⚠ بديلاً عن الخبرة أو الشهادات المهنية.

هو بداية منظمة وصحيحة، تبني عليها.

كيف يسير كل موضوع في الكورس

1
شرح مبسط
الفكرة بلغة واضحة.

←

2
مثال محلول
نطبقها أمامك على رُفاد.

←

3
تمرين قصير
تحاول بنفسك في الكراسة.

←

4
إجابة نموذجية
نقارن ونشرح لماذا.

مثال محلول · تمرين · توقف وطبّق · الإجابة النموذجية ابحث عن هذه العلامات أعلى الشرائح.

حين ترى «توقف وطبّق»: أوقف الفيديو مؤقتاً، واكتب إجابتك في الكراسة قبل أن تنتقل إلى الإجابة النموذجية.

لمن هذا الكورس؟

خريج بلا خبرة

من أي تخصص: حاسب، أو نظم، أو إدارة، أو قانون، أو محاسبة.

موظف تقنية يريد التحول

دعم فني، أو شبكات، أو تطوير، ويريد مساراً يجمع التقنية بالإدارة.

مختص تدقيق أو قانون أو جودة

يملك نصف المهارة، ويحتاج لغة الأمن السيبراني.

لا تحتاج خلفية في الأمن السيبراني. تحتاج فضولاً، وكتابة واضحة، واستعداداً للتطبيق.

خريطة الكورس: ثماني وحدات من الفكرة إلى الوظيفة

المعرفة والتطبيق: الوحدات 1 إلى 4

01
ما هو GRC؟
الفكرة، والأدوار، ويوم العمل

02
المفاهيم وتطبيقاتها
حوكمة، ومخاطر، وامتثال

03
الأطر والانطباق
ما الذي ينطبق على الجهة؟

04
الشهادات
لمن، ومتى، وكيف تختار

الوصول إلى الوظيفة: الوحدات 5 إلى 8

05
خطة البداية
مشاريع وملف أعمال

06
السيرة الذاتية
إنجازات تُقرأ

07
لينكدإن والفرص
ملف يجده الباحث

08
المقابلة والانطلاق
إجابات وخطة

الحالة العملية: شركة رُفاد

رُفاد للخدمات اللوجستية

شركة افتراضية متوسطة الحجم في الرياض، نحو 200 موظف، تقدم خدمات التوصيل والتخزين للمتاجر الإلكترونية.

نظام الموارد البشرية والرواتب	خدمة سحابية. بيانات الموظفين ورواتبهم وحساباتهم البنكية. المالكة: مديرة الموارد البشرية.
البريد والملفات السحابية	منصة بريد وتخزين سحابية لكل الموظفين. المالك: مدير تقنية المعلومات.
تطبيق تتبع الشحنات	على خادم سحابي. أسماء المستلمين وهواتفهم وعناوينهم. المالك: مدير تقنية المعلومات.
المورد: شركة سَنَد للحلول التقنية	مورد افتراضي للدعم الفني وإدارة الخوادم عن بعد، بعقد سنوي.

⚠ رُفاد شركة افتراضية لأغراض التدريب. اسمها وأشخاصها وأنظمتها وبياناتها وأدلتها مختلقة، وأي تشابه مع جهة حقيقية غير مقصود.

عن ECC في الحالة

رُفاد شركة خاصة ليست جهة حكومية ولا تابعة لجهة حكومية، ولا تملك بنية تحتية وطنية حساسة، فالضوابط الأساسية ECC-2:2024 غير ملزمة لها. في هذه الحالة التدريبية تبنّتها رُفاد طوعاً مرجعاً داخلياً.

من يفعل ماذا في رُفاد

الدور	الشخص	ماذا يفعل في الحالة
الرئيس التنفيذي	أ. خالد	صاحب الصلاحية: يعتمد السياسات ويقبل المخاطر
لجنة الأمن السيبراني	يرأسها الرئيس التنفيذي	تشرف وتتابع كل ربع سنة
مسؤولة GRC	أ. ريم	الخط الثاني: المنهجية والمتابعة والتقارير
محلل GRC متدرب	أنت	تساعد ريم في كل تطبيقات الكورس
مدير تقنية المعلومات	م. سلمان	يملك الأنظمة التقنية ويشرف على المورد
مديرة الموارد البشرية	أ. منى	مالكة نظام الموارد البشرية والرواتب
المدير المالي	أ. فهد	العقود والمشتريات

01 ما هو GRC؟

قبل المصطلحات والأطر: ما العمل الذي يقوم به مختص GRC، ولماذا تحتاجه كل جهة؟

بعد هذه الوحدة ستستطيع أن:

- تشرح GRC بثلاثة أسئلة وبمثال من رُفاد.
- تعرف لماذا تحتاجه الجهات، وأين يقع بين أدوار الأمن.
- تعرف شكل يوم العمل والمسميات المبتدئة.

ثلاث كلمات، وسؤال لكل منها

Governance

الحوكمة

من يقرر، وبأي قواعد، وكيف نتابع؟

ما تنتجه: سياسات معتمدة، ولجنة، وأدوار.

في رُفاد: الرئيس التنفيذي يعتمد سياسة الأمن السيبراني.

Risk

المخاطر

ما الذي قد يضرنا، وماذا نفعل حياله؟

ما تنتجه: سجل مخاطر وخطط معالجة.

في رُفاد: تقييم خطر حساب المورد المشترك.

Compliance

الامتثال

هل نلتزم، وكيف نثبت؟

ما تنتجه: تقييمات، وأدلة، وملاحظات.

في رُفاد: فحص أدلة مراجعة صلاحيات نظام الرواتب.

الحوكمة تضع القواعد، والمخاطر تحدد الأولويات، والامتثال يثبت التطبيق.

لماذا تحتاج كل جهة من يعمل في GRC؟

1
أنظمة وعقود

جهات كثيرة ملزمة بأنظمة وضوابط، والعملاء يطلبون التزامات في العقود. أحدٌ يجب أن يحول النص إلى تطبيق.

2
موارد محدودة

لا تستطيع جهة أن تحمي كل شيء بالقدر نفسه. تقييم المخاطر يحدد أين تبدأ.

3
ثقة تحتاج دليلاً

الجهات الرقابية والعملاء والشركاء يطلبون إثباتاً، لا وعداً.

في رُفاد: نظام حماية البيانات الشخصية ينطبق عليها، وعملاؤها من المتاجر يسألون عن حماية بيانات المستلمين.

أين يقع GRC بين أدوار الأمن السيبراني؟

الدور	السؤال الذي يجيب عنه	يوم العمل
GRC	هل نحمي ما يهم، وهل نلتزم ونثبت؟	سياسات، وتقييم مخاطر، وفحص أدلة، ومتابعة
مركز العمليات	هل يحدث هجوم الآن؟	فرز التنبيهات، والتحقيق، والتصعيد
اختبار الاختراق	كيف يمكن اختراقنا؟	اختبار الأنظمة وكتابة تقارير الثغرات
هندسة الأمن	كيف نبني الحماية؟	تصميم الضوابط التقنية وتشغيلها

مختص GRC لا ينفذ الضوابط التقنية بنفسه غالباً، لكنه يفهمها بما يكفي ليسأل الأسئلة الصحيحة ويقرأ الدليل.

المسميات التي ستراها في الإعلانات

المسمى الذي ستراه	ماذا يفعل غالباً	أين يعمل
محلل GRC أو محلل امتثال	تقييم فجوات، وأدلة، ومتابعة خطط	الخط الثاني
محلل مخاطر الأمن السيبراني	سجل المخاطر، والتقييم، والتقارير	الخط الثاني
مسؤول سياسات الأمن السيبراني	كتابة السياسات والمعايير ومراجعتها	الخط الثاني
مقيّم الضوابط الأمنية	اختبار الضوابط وجمع الأدلة	الثاني أو الثالث
مدقق تقنية معلومات مبتدئ	تدقيق مستقل وتقارير ملاحظات	الخط الثالث

المسميات تختلف بين الجهات. بعضها من فئة «الحوكمة والمخاطر والامتثال والأنظمة» في الإطار السعودي لكوادر الأمن السيبراني SCyWF-1.5:2026.

يوم في عمل محلل GRC مبتدئ في رُفاد

08:00 طلبات الأدلة: الموارد البشرية أرسلت ملف المراجعة، وتقنية المعلومات تأخرت.

09:00 متابعة خطة معالجة خطر المورد مع سلمان.

10:30 تحديث سجل المخاطر بخطر جديد من مشروع ترحيل نظام الرواتب.

12:00 فحص دليل: هل تكفي لقطة الإعداد، أم نطلب سجل التغييرات؟

14:00 مسودة إجراء إلغاء صلاحيات المغادرين.

15:30 شريحتان للجنة: المخاطر العالية والملاحظات المفتوحة.

مثال توضيحي مركّب. اليوم الفعلي يختلف حسب الجهة وحجمها وموسم التقييم.

أربع خرافات تؤخر البداية

«GRC أوراق وسياسات فقط»

السياسة بداية العمل. الجزء الأكبر هو التحقق من تطبيقها بالأدلة.

«لا يدخله إلا أصحاب الخبرة»

توجد وظائف مبتدئة، والمشاريع العملية تعوض جزءاً من الخبرة.

«لا يحتاج معرفة تقنية»

تحتاج أساسيات تكفي لتسأل وتفهم الدليل: الهويات، والشبكات، والسجلات، والسحابة.

«تكفي شهادة واحدة»

الشهادة تفتح باب المقابلة. ما يقنع هو أن تشرح مثالاً عملياً.

صنّف مهام رُفاد: حوكمة أم مخاطر أم امتثال؟

#	المهمة في رُفاد	G أو R أو C؟
1	الرئيس التنفيذي يعتمد سياسة الأمن السيبراني	
2	تقدير احتمال وأثر سرقة حاسوب عليه ملفات الرواتب	
3	جمع أدلة مراجعة الصلاحيات لتقييم الالتزام بـ ECC	
4	تشكيل لجنة الأمن السيبراني وتحديد مهامها	
5	اختيار خطة معالجة لخطر حساب المورد المشترك	
6	مطابقة عقد المورد مع بنود ECC 4-1-2	

اكتب الحرف في الكراسة، وسبباً من جملة واحدة لكل مهمة. 4 دقائق.

الإجابة: G وR وC في مهام رُفاد

#	المهمة	الإجابة	لماذا
1	الرئيس التنفيذي يعتمد سياسة الأمن السيبراني	G	قرار ممن يملك الصلاحية يضع القواعد.
2	تقدير احتمال وأثر سرقة حاسوب عليه ملفات الرواتب	R	تحليل ما قد يحدث وحجمه لترتيب الأولوية.
3	جمع أدلة مراجعة الصلاحيات لتقييم الالتزام بـ ECC	C	إثبات تطبيق متطلب محدد بالأدلة.
4	تشكيل لجنة الأمن السيبراني وتحديد مهامها	G	هيكل إشراف ومسؤوليات ومتابعة.
5	اختيار خطة معالجة لخطر حساب المورد المشترك	R	قرار معالجة لخطر قُيّم مستواه.
6	مطابقة عقد المورد مع بنود ECC 4-1-2	C	مقارنة الوضع القائم بمتطلب مكتوب.

المهام متداخلة في الواقع: اعتماد خطة معالجة للخطر قرار حوكمة أيضاً. المهم أن تعرف السؤال الأساسي الذي تجيب عنه كل مهمة.

02 المفاهيم وتطبيقاتها

أطول وحدة وأهمها: ثلاثة أجزاء، وأربعة تطبيقات تنفذها بنفسك على رُفاد.

بعد هذه الوحدة ستستطيع أن:

- تحدد المسؤوليات بمصفوفة RACI، وتكتب بند سياسة من متطلب.
- تكتب خطراً وتقيمه بمصفوفة الإطار الوطني، وتحدد معالجته.
- تفحص أدلة ضابط، وتكتب ملاحظة وخطة تصحيح.

الجزء الأول

الحوكمة

من يقرر، وبأي قواعد، ومن المسؤول عن ماذا؟

- الحوكمة والإدارة والتشغيل
- الأدوار والمسؤوليات
- نموذج الخطوط الثلاثة
- هرم الوثائق ودورة حياة السياسة
- مصفوفة RACI
- التطبيق 1: مسؤوليات وبند سياسة

الحوكمة والإدارة والتشغيل: قرار واحد بثلاثة مستويات

الحوكمة

ماذا نريد، ولماذا، ومن يحاسب؟

من: صاحب الصلاحية واللجنة

مثال رُفاد: اعتماد قرار: التحقق متعدد العوامل إلزامي للدخول عن بعد.

الإدارة

كيف ننفذ القرار، وبأي موارد وجدول؟

من: مدراء الإدارات

مثال رُفاد: خطة نشر خلال 6 أسابيع، وميزانية، ومسؤول لكل مرحلة.

التشغيل

من ينفذ العمل يومياً؟

من: الفرق والمورد

مثال رُفاد: تسجيل أجهزة الموظفين في تطبيق التحقق.

القرار نفسه يمر بالمستويات الثلاثة. والحوكمة تعود في النهاية لتتابع: هل تحقق ما قررناه؟

صنّف أنشطة رُفاد: حوكمة أم إدارة أم تشغيل؟

#	النشاط في رُفاد	حوكمة أم إدارة أم تشغيل؟
1	اعتماد قرار: «التحقق متعدد العوامل إلزامي للدخول عن بعد»	
2	خطة نشر التحقق متعدد العوامل خلال 6 أسابيع وميزانيتها	
3	تسجيل جهاز الموظف في تطبيق التحقق	
4	تقرير ربع سنوي للجنة عن نسبة الحسابات المفعّل عليها التحقق	

اكتب المستوى وسبباً قصيراً لكل نشاط. 3 دقائق.

الإجابة: مستويات أنشطة رُفاد

#	النشاط	المستوى	لماذا
1	اعتماد قرار: «التحقق متعدد العوامل إلزامي للدخول عن بعد»	حوكمة	قرار وتوجه يعتمده صاحب الصلاحية.
2	خطة نشر التحقق متعدد العوامل خلال 6 أسابيع وميزانيتها	إدارة	تخطيط الموارد والجدول لتنفيذ القرار.
3	تسجيل جهاز الموظف في تطبيق التحقق	تشغيل	تنفيذ يومي للإجراء.
4	تقرير ربع سنوي للجنة عن نسبة الحسابات المفعّل عليها التحقق	حوكمة	متابعة وإشراف ومساءلة من الجهة الأعلى.

النشاط الرابع يخدع كثيرين: التقرير للجنة ليس عملاً إدارياً عادياً، بل متابعة وإشراف، وهما جزء من الحوكمة.

ستة أدوار تتكرر في كل عمل GRC

الدور	مسؤوليته	في رُفاد
صاحب الصلاحية	يعتمد السياسات ويقبل المخاطر	الرئيس التنفيذي خالد
اللجنة	تشرف، وتتابع، وتوصي	لجنة الأمن السيبراني
GRC	تضع المنهجية، وتراقب، وتبلغ	ريم، وأنت معها
مالك النظام	مسؤول عن النظام وبياناته	منى لنظام الرواتب
مالك الضابط	يطبق الضابط ويحتفظ بأدلته	سلمان للتحقق متعدد العوامل
مالك الخطر	يقرر معالجة الخطر ويتابعها	منى لخطر ملفات الرواتب

GRC لا ينفذ كل الضوابط، ولا يملك كل المخاطر

ما يفعله GRC

- يضع المنهجية والنماذج.
- يساعد الإدارات على فهم المتطلبات.
- يتحقق من التطبيق بالأدلة.
- يرفع الصورة بوضوح للإدارة واللجنة.

ما لا يفعله GRC

- لا ينفذ كل الضوابط بنفسه.
- لا يملك مخاطر الإدارات الأخرى.
- لا يعتمد السياسات بدل صاحب الصلاحية.
- لا يتحمل الخطأ عن كل الجهة.

في رُفاد: ريم لا تعطّل حسابات المغادرين. سلمان يعطّلها، وريم تتحقق أن ذلك يحدث فعلاً.

نموذج الخطوط الثلاثة في رُفاد

جهة الحوكمة: الرئيس التنفيذي ولجنة الأمن السيبراني، تحدد التوجه وتحاسب.

الخط الأول

الإدارات التشغيلية

تملك المخاطر وتطبق الضوابط. في رُفاد: سلمان ومنى والمورد تحت إشرافهما.

الخط الثاني

المخاطر والامتثال

يضع الإطار ويراقب ويتحدى. في رُفاد: ريم، وأنت معها.

الخط الثالث

المراجعة الداخلية

تأكيد مستقل. في رُفاد: مراجع خارجي متعاقد معه سنوياً.

النموذج من معهد المدققين الداخليين IIA. توزيع الأدوار يختلف من جهة لأخرى.

هرم الوثائق: من «لماذا» إلى «كيف»

السياسة
ماذا ولماذا · يعتمدها صاحب الصلاحية

«تُراجع الصلاحيات دورياً في كل الأنظمة.»

المعيار
قيم ملزمة قابلة للقياس

«نظام الرواتب: مراجعة كل 3 أشهر، وإزالة خلال 5 أيام عمل.»

الإجراء
خطوات: من يفعل ماذا ومتى

«تصدّر تقنية المعلومات القائمة، ثم يؤكد كل مدير...»

الإرشاد
توصيات غير ملزمة

«يُنصح بمراجعة الحسابات غير المستخدمة منذ 90 يوماً أولاً.»

مثال واحد عبر المستويات الأربعة: مراجعة الصلاحيات في رُفاد. القيم مثال تدريبي.

دورة حياة السياسة: سبع مراحل

1 تحديد الحاجة والمتطلبات
نظام، أو ضابط، أو خطر، أو حادثة.

2 الصياغة
مسودة بلغة واضحة وقابلة للتدقيق.

3 المراجعة
الإدارات المعنية والقانونية وGRC.

4 الاعتماد
من صاحب الصلاحية، بتاريخ وإصدار.

5 النشر
لمن تنطبق عليهم، مع توعية.

6 التطبيق
إجراءات وضوابط وأدلة.

7 المراجعة الدورية
سنوياً أو عند التغيير.

ثم تعود الدورة من البداية

في رُفاد: سياسة التحكم بالوصول تُراجع سنوياً، أو فوراً عند تغيير نظام مهم مثل ترحيل نظام الرواتب.

مصفوفة RACI: أربعة حروف قبل أن نبدأ

R المنفّذ
Responsible

من يقوم بالعمل فعلاً. قد يكونون أكثر من واحد.

A المساءَل
Accountable

من يحاسَب على النتيجة ويعتمدها. واحد فقط.

C المستشار
Consulted

يؤخذ رأيه قبل التنفيذ: تواصل باتجاهين.

I المُبلَّغ
Informed

يُخبر بالنتيجة بعد التنفيذ: اتجاه واحد.

قاعدة واحدة تمنع أغلب الأخطاء: A واحد لكل نشاط. وقد يكون الشخص نفسه A وR معاً.

من متطلب إلى بند سياسة: أربع خطوات

1
اقرأ المتطلب
ماذا يطلب بالضبط؟

←

2
حدد قرار الجهة
النطاق والمدة والمسؤول.

←

3
اكتب البند
جملة إلزامية واضحة.

←

4
اختبره
هل يمكن تدقيقه بدليل؟

معايير البند الجيد

- ✓ يحدد النطاق: أي أنظمة أو أشخاص.
- ✓ يحدد المسؤول بالوظيفة.
- ✓ يحدد المدة أو التكرار.
- ✓ بصيغة إلزامية: «يجب» أو «تُ...».
- ✓ ينتج دليلاً يمكن طلبه.
- ✓ لا يكرر نص الضابط حرفياً.

مثال محلول: المتطلب وقرار الجهة

> ECC 2-2-3-5: يجب أن تغطي متطلبات إدارة هويات الدخول والصلاحيات بحد أدنى: المراجعة الدورية لهويات الدخول والصلاحيات.

الوضع في رُفاد

نظام الموارد البشرية والرواتب فيه 214 حساباً، ولا توجد مراجعة دورية للصلاحيات حتى الآن.

قرار رُفاد

قررت رُفاد مراجعة ربع سنوية لهذا النظام لأنه يحتوي رواتب الموظفين وحساباتهم البنكية. الضابط يقول «دورية» ولا يحدد المدة؛ الجهة تحددها بناءً على المخاطر وتوثقها.

⚠ الضابط لا يحدد المدة. لا تخترع رقماً «من الضابط»؛ اكتب أنه قرار الجهة ومبرره.

مثال محلول: مصفوفة RACI لمراجعة الصلاحيات

النشاط	مالكة النظام	مدير الموظف	تقنية المعلومات	GRC
تصدير قائمة المستخدمين وصلاحياتهم	A		R	I
تأكيد حاجة كل موظف لصلاحيته	A	R		C
اعتماد نتيجة المراجعة	A/R	I	I	I
إزالة الصلاحيات غير المبررة	I		A/R	I
متابعة الإنجاز وحفظ الأدلة	A		C	R

A واحد في كل صف. GRC يتابع ويحفظ الأدلة، ولا ينفذ الإزالة.

مثال محلول: بند السياسة

تُراجع هويات الدخول والصلاحيات في نظام الموارد البشرية والرواتب كل ثلاثة أشهر على الأقل. تعتمد مالكة النظام نتيجة المراجعة خلال 10 أيام عمل من تصدير القائمة، وتُزال الصلاحيات غير المبررة خلال 5 أيام عمل من الاعتماد، وتُحفظ أدلة المراجعة والإزالة سنتين على الأقل.

لماذا هذا بند جيد؟

- ✓ النطاق: نظام الموارد البشرية والرواتب
- ✓ التكرار: كل 3 أشهر
- ✓ المسؤول: مالكة النظام
- ✓ المدد: اعتماد خلال 10 أيام، وإزالة خلال 5
- ✓ الدليل: ملف المراجعة وأدلة الإزالة

دورك: إلغاء صلاحيات المغادرين

ECC 1-9-5: يجب مراجعة وإلغاء الصلاحيات للعامل مباشرة بعد انتهاء/إنهاء العلاقة الوظيفية مع الجهة.

ما وجدته في رُفاد

- تسجل الموارد البشرية الاستقالات في نظام الموارد البشرية والرواتب.
- تعرف تقنية المعلومات بالمغادرين عبر رسائل غير رسمية من المدراء.
- المورد سَنَد يعطل حساب البريد حين تطلب منه تقنية المعلومات ذلك.
- لا أحد يتحقق من حسابات نظام الرواتب وتطبيق التتبع والوصول عن بعد.
- الشهر الماضي غادر 4 موظفين، وبقي حسابان منهم نشطين بعد 3 أسابيع.

دورك: المطلوب والنموذج

1. اكتب خمسة أنشطة لعملية إلغاء صلاحيات المغادرين.
2. املأ مصفوفة RACI، مع مسؤول A واحد لكل نشاط.
3. اكتب بند سياسة من جملتين أو ثلاث يحقق معايير البند الجيد.

النشاط	الموارد البشرية	مدير الموظف	تقنية المعلومات	GRC
النشاط 1				
النشاط 2				
...				

بند السياسة

اكتب جملتين أو ثلاثاً هنا...

النموذج كاملاً في الكراسة. 15 دقيقة.

الإجابة: مصفوفة RACI لإلغاء صلاحيات المغادرين

النشاط	الموارد البشرية	مدير الموظف	تقنية المعلومات	GRC
إشعار انتهاء العلاقة الوظيفية فور تحديد آخر يوم عمل	A/R	C	I	
إلغاء الحسابات والصلاحيات في كل الأنظمة	I	I	A/R	
توثيق الإلغاء في تذكرة مغلقة بأدلتها	I		A/R	I
مطابقة شهرية: المغادرون مقابل الحسابات النشطة	C		A/R	I
مراقبة فاعلية الإجراء وإبلاغ اللجنة	C		C	A/R

المورد ينفذ الإلغاء تحت إشراف تقنية المعلومات، فهي المساءلة. المسؤولية لا تنتقل إلى المورد.

الإجابة: بند السياسة ولماذا

يجب إلغاء جميع حسابات العامل وصلاحياته في أنظمة رُفاد، بما فيها حسابات الوصول عن بعد، في موعد أقصاه نهاية آخر يوم عمل له. تُشعر الموارد البشرية تقنية المعلومات فور تحديد آخر يوم عمل، وتنفذ تقنية المعلومات الإلغاء وتوثقه في تذكرة، وتطابق شهرياً قائمة المغادرين مع الحسابات النشطة.

لماذا هكذا؟

- ✓ الموارد البشرية مصدر الحقيقة عن انتهاء العلاقة الوظيفية، فهي A وR للإشعار.
- ✓ التنفيذ عند تقنية المعلومات، والمورد ينفذ تحت إشرافها؛ المسؤولية لا تنتقل إلى المورد.
- ✓ المطابقة الشهرية ضابط كشفي يلتقط ما فات، ويملكه الخط الأول لا GRC.
- ✓ GRC يراقب ويبلغ، ولا ينفذ الإلغاء بنفسه حتى يبقى قادراً على التحقق باستقلالية.

التطبيق 1: أخطاء شائعة

كيف تتجنبها

- A واحد في كل صف، وراجع الصفوف بعد التعبئة.
- الخط الأول ينفذ، وGRC يتحقق.
- موعد محدد ومسؤول بالوظيفة ودليل.
- غطّ كل الأنظمة، بما فيها الوصول عن بعد.
- البند يقول كيف ستلتزم الجهة، لا يكرر الضابط.

أخطاء شائعة

- ⚠ وضع GRC مسؤولاً عن تعطيل الحسابات.
- ⚠ أكثر من A في النشاط الواحد، أو نشاط بلا A.
- ⚠ بند غامض: «تُلغى الصلاحيات في الوقت المناسب».
- ⚠ نسيان حسابات الوصول عن بعد ونظام الرواتب وتطبيق التتبع.
- ⚠ نسخ نص الضابط كما هو دون تحديد من ومتى وما الدليل.

الجزء الثاني

المخاطر

ما الذي قد يحدث، وما حجمه، وماذا نفعل حياله؟

ثلاثية الأمن
مصطلحات المخاطر
صياغة الخطر
الإطار الوطني لإدارة المخاطر
مصفوفة التقييم
المتأصل والمتبقي
المعالجة والشهية
الضوابط
سجل المخاطر
التطبيق 2

ثلاثية الأمن: ما الذي نحميه في المعلومات؟

السرية Confidentiality

لا يطّلع على المعلومة إلا المخوَّل.

ما يهددها في رُفاد: تسرب ملف الرواتب.

ما يحميها: الصلاحيات والتشفير.

السلامة Integrity

المعلومة صحيحة ولم تُغيَّر دون إذن.

ما يهددها في رُفاد: تغيير رقم الحساب البنكي لموظف في نظام الرواتب.

ما يحميها: فصل المهام وسجلات التغيير.

التوافر Availability

الخدمة متاحة وقت الحاجة.

ما يهددها في رُفاد: توقف تطبيق التتبع يوم ذروة.

ما يحميها: النسخ الاحتياطي وخطة التعافي.

في كل خطر اسأل: أي الثلاثة يمس؟ الإجابة تحدد الضابط المناسب وحجم الأثر.

ستة مصطلحات للمخاطر، بمثال واحد

المثال الذي سنحمله حتى نهاية الجزء: حاسوب أخصائي الرواتب في رُفاد، وعليه ملفات تصدير الرواتب.

الأصل

ما له قيمة للجهة.

مثال: الحاسوب وملفات الرواتب.

التهديد

ما قد يسبب الضرر.

مثال: سرقة الحاسوب من السيارة.

الثغرة

ضعف يسهّل الضرر.

مثال: القرص غير مشفر.

الاحتمال

فرصة الحدوث خلال فترة.

مثال: الموظف يتنقل بالحاسوب يومياً.

الأثر

حجم الضرر إن حدث.

مثال: تسرب رواتب كل الموظفين.

الخطر

تهديد يستغل ثغرة في أصل، باحتمال وأثر.

مثال: «تسرب الرواتب بسرقة حاسوب غير مشفر».

كيف نكتب الخطر: سبب، وحدث، وأثر

بسبب... (الثغرة أو السبب) قد... (الحدث) مما يؤدي إلى... (الأثر)

بسبب حفظ ملفات تصدير الرواتب على حاسوب محمول غير مشفر، قد يؤدي فقدانه أو سرقته إلى اطلاع غير مصرح به على رواتب 200 موظف وحساباتهم البنكية، مما يضر الموظفين ويعرض رُفاد لمخالفة نظام حماية البيانات الشخصية ولضرر في سمعتها.

صياغة جيدة

- سبب، وحدث، وأثر في جملة واحدة.
- يفهمها مالك الخطر دون شرح.

صياغة ضعيفة

- «لا يوجد تشفير». هذه ثغرة.
- «خطر أمني على الحاسوب». بلا حدث ولا أثر.

من أين نكتشف المخاطر؟ سجل الأصول، والحوادث السابقة، وتقارير الثغرات، والتدقيق، والتغييرات والمشاريع، والموردون.

الإطار الوطني لإدارة مخاطر الأمن السيبراني

الاسم والإصدار الإطار الوطني لإدارة مخاطر الأمن السيبراني NFCRM-1:2025، صدر 23 يوليو 2025.

على من ينطبق الجهات الحكومية وما يتبعها، وجهات القطاع الخاص التي تملك أو تشغل أو تستضيف بنية تحتية وطنية حساسة.

في رُفاد غير ملزم لها. تبنت مصفوفته طوعاً في الحالة التدريبية.

1 التحديد
الأصول، والثغرات، والتهديدات، والسيناريوهات، والضوابط الحالية.

←

2 التقييم
الاحتمال والأثر بالمصفوفة، والتوثيق في السجل.

←

3 المعالجة
قبول، أو مشاركة، أو تخفيف، أو تجنب، بخطط وأولويات.

←

4 المتابعة
تقارير، ومراقبة الخطط، وإعادة التقييم عند التغيير.

مستويات الاحتمال في الإطار الوطني

القيمة	المستوى	الإطار الزمني	أو: سهولة الاستغلال
5	شبه مؤكد	يتكرر غالباً، عدة مرات في السنة.	يستغله مهاجم غير محترف بأداة جاهزة.
4	محتمل	يحدث غالباً مرة في السنة.	يستغله مهاجم متقدم بأدوات خاصة.
3	غير مرجح	قد يحدث مرة كل 2 إلى 3 سنوات.	يستغله متقدم بشروط محددة فقط.
2	نادر	مرة كل 3 إلى 10 سنوات.	غير قابل للاستغلال مباشرة الآن.
1	نادر جداً	أقل من مرة كل 10 إلى 20 سنة.	لا يُعد قابلاً للاستغلال حالياً.

ملخص من الشكل 5 في NFCRM-1:2025. يُختار المستوى بالإطار الزمني أو بسهولة الاستغلال.

مستويات الأثر في الإطار الوطني

القيمة	المستوى	الأثر عند المساس بالسرية أو السلامة أو التوافر
5	حرج	أثر كبير لا تحتمله الجهة، أو أثر على المستوى الوطني.
4	عالٍ	أثر كبير على الجهة.
3	متوسط	أثر ملموس على الجهة.
2	منخفض	أثر طفيف على الجهة.
1	منخفض جداً	لا أثر على الجهة، أو بيانات غير حساسة.

في رُفاد: تسرب رواتب وحسابات 200 موظف أثر كبير على الجهة، فهو «عالٍ» (4).

ملخص من الشكل 4 في NFCRM-1:2025، ويصف الإطار كل مستوى للسرية والسلامة والتوافر منفصلة.

المصفوفة: الاحتمال × الأثر

مثال الحاسوب

الاحتمال 3 × الأثر 4 = 12

12 يقع بين 8 و14: «متوسط».

حسب قاعدة رُفاد: خطة معالجة، أو قبول موثق من الرئيس التنفيذي.

حرج	عالٍ	متوسط	منخفض	منخفض جداً
20–25	15–19	8–14	3–7	1–2

الاحتمال ↑ الأثر →	1 منخفض جداً	2 منخفض	3 متوسط	4 عالٍ	5 حرج
5 شبه مؤكد	5 منخفض	10 متوسط	15 عالٍ	20 حرج	25 حرج
4 محتمل	4 منخفض	8 متوسط	12 متوسط	16 عالٍ	20 حرج
3 غير مرجح	3 منخفض	6 منخفض	9 متوسط	12 متوسط	15 عالٍ
2 نادر	2 منخفض جداً	4 منخفض	6 منخفض	8 متوسط	10 متوسط
1 نادر جداً	1 منخفض جداً	2 منخفض جداً	3 منخفض	4 منخفض	5 منخفض

المصفوفة والمستويات كما وردت في الشكلين 2 و3 من NFCRM-1:2025.

لماذا 3 و4؟ مبرر كل درجة

الاحتمال 3 يتنقل الموظف يومياً بالحاسوب، وسُجلت في رُفاد سرقة حاسوب واحدة خلال 3 سنوات: «غير مرجح» قد يقع مرة كل 2 إلى 3 سنوات.

الأثر 4 تسرب بيانات حساسة لكل الموظفين بأثر كبير على الجهة: «عالٍ».

ما الذي يغير الدرجة؟

- لو سُرق حاسوبان في السنة الماضية، يرتفع الاحتمال إلى 4.
- لو كانت الملفات أسماء فقط بلا رواتب أو حسابات، ينخفض الأثر.
- الدرجة تُكتب مع مبررها في السجل، ليراجعها غيرك.

الخطر المتأصل والمتبقي: الانخفاض ليس تلقائياً

المتأصل: قبل خطة المعالجة

الاحتمال 3 × الأثر 4

12 · متوسط

المتبقي المتوقع: بعد التشفير

الاحتمال 3 × الأثر 2

6 · منخفض

بشرط أن:

- ✓ التشفير مفعّل ومُتحقق منه على كل الأجهزة المعنية، لا على بعضها.
- ✓ الجهاز محمي بكلمة مرور قوية، ومفاتيح الاسترداد محفوظة بأمان.
- ✓ لا تبقى نسخ من ملفات الرواتب خارج المجلد المقيد.

⚠ التشفير لا يمنع السرقة، فالاحتمال لا يتغير. يقلل الأثر فقط، وبشرط أن يعمل فعلاً على كل الأجهزة.

أربعة خيارات لمعالجة الخطر

التخفيف

ضوابط تقلل الاحتمال أو الأثر.

في رُفاد: تشفير حواسيب الرواتب.

التجنب

إيقاف النشاط المسبب للخطر.

في رُفاد: منع حفظ ملفات الرواتب على الأجهزة.

المشاركة

تحميل جزء من الأثر لطرف آخر.

في رُفاد: تأمين، أو عقد. المسؤولية لا تنتقل.

القبول

قرار موثق ممن يملك الصلاحية.

في رُفاد: قبول مؤقت مع موعد مراجعة.

⚠ قبول الخطر قرار داخلي. لا يلغي التزاماً نظامياً، ولا يمنح إعفاءً من جهة تنظيمية.

شهية المخاطر وحدود التحمل

شهية المخاطر

حجم الخطر الذي تقبله الجهة عموماً لتحقق أهدافها. يقررها المجلس أو صاحب الصلاحية.

> «لا نقبل مخاطر عالية على بيانات الموظفين والعملاء.»

حدود التحمل

حدود قابلة للقياس تطبق الشهية على خطر أو مؤشر محدد.

> «لا يبقى خطر عالٍ بلا خطة أكثر من 30 يوماً.» «توقف الرواتب لا يتجاوز يوم عمل.»

المستوى	القرار في رُفاد
منخفض جداً أو منخفض	يقبله مالك الخطر ويوثقه
متوسط	خطة معالجة، أو قبول موثق من الرئيس التنفيذي
عالٍ أو حرج	معالجة إلزامية، وعرض على اللجنة

الضوابط: طبيعتها ووظيفتها

الطبيعة	وقائي: يمنع	كشفي: يكتشف	تصحيحي: يعالج
إداري	سياسة الاستخدام، والتوعية	مراجعة الصلاحيات الدورية	خطة الاستجابة للحوادث
تقني	التحقق متعدد العوامل، والتشفير	تنبيهات الدخول، وسجلات الأحداث	الاستعادة من النسخ
مادي	أقفال غرفة الخوادم	كاميرات المراقبة	موقع بديل

صنّف الضابط بالبعدين معاً: «التحقق متعدد العوامل ضابط تقني وقائي».

الضابط التعويضي بديل يحقق الهدف نفسه حين يتعذر الأصلي.

صف مكتمل في سجل المخاطر

الوصف: بسبب حفظ ملفات تصدير الرواتب على حاسوب محمول غير مشفر، قد يؤدي فقدانه أو سرقته إلى اطلاع غير مصرح به على رواتب 200 موظف وحساباتهم البنكية، مما يضر الموظفين ويعرض رُفاد لمخالفة نظام حماية البيانات الشخصية ولضرر في سمعتها.

الرقم	R-07
الأصل	حاسوب أخصائي الرواتب وملفات تصدير الرواتب
الضوابط الحالية	كلمة مرور لحساب الجهاز، وسياسة الاستخدام المقبول. لا تشفير للقرص.
التقييم الحالي	3 × 4 = 12 · متوسط
مالك الخطر	مديرة الموارد البشرية
المعالجة	التخفيف: تشفير القرص الكامل لحواسيب الموارد البشرية والمالية، وحفظ ملفات الرواتب في مجلد سحابي مقيد بدل الجهاز.
مالك الإجراء	مدير تقنية المعلومات
الموعد	30 يوماً
المتبقي المتوقع	3 × 2 = 6 · منخفض
المتابعة	تتحقق GRC من تقرير التشفير بعد 30 يوماً، وتحدّث السجل.

دورك: حساب المورد المشترك

ما وجدته في رُفاد

- سَنَد يدير خادم تطبيق التتبع عن بعد بأداة دعم مكشوفة على الإنترنت.
- حساب إداري مشترك واحد «sanad-admin» يستخدمه 5 فنيين.
- كلمة المرور لم تتغير منذ 2023، ولا يوجد تحقق متعدد العوامل.
- الوصول مفتوح على مدار الساعة دون طلب أو موافقة.
- الأداة تحفظ سجلات الجلسات 30 يوماً، ولا أحد يراجعها.
- العقد فيه بند سرية فقط: لا إبلاغ عن الحوادث ولا التزام بسياسات رُفاد.
- الخادم يحفظ أسماء المستلمين وهواتفهم وعناوينهم: نحو 50 ألف مستلم شهرياً.

دورك: المطلوب والنموذج

1. اكتب الخطر بصيغة: بسبب... قد... مما يؤدي إلى...
2. اذكر الضوابط الحالية.
3. قدّر الاحتمال والأثر بأوصاف المصفوفة، وبرر كلاً منهما، ثم احسب المستوى.
4. اقترح معالجة: خيار، وثلاثة إجراءات، لكل منها مالك وموعد.
5. قدّر الخطر المتبقي المتوقع واذكر افتراضاتك.

وصف الخطر

بسبب... قد... مما يؤدي إلى...

الاحتمال والأثر

... × ... = ...، والمبرر:

المعالجة

الخيار، والإجراءات، والمالك، والموعد

استخدم المصفوفة في الشريحة 44. النموذج كاملاً في الكراسة. 20 دقيقة.

الإجابة: الوصف والتقييم

بسبب استخدام حساب إداري مشترك لمورد الدعم عبر أداة وصول عن بعد مكشوفة على الإنترنت بلا تحقق متعدد العوامل، قد يستخدم مهاجم كلمة مرور مسربة أو مخمّنة للدخول إلى خادم تطبيق التتبع، مما يؤدي إلى تسرب البيانات الشخصية للمستلمين أو تعطيل خدمة التتبع.

الضوابط الحالية كلمة مرور قديمة، وبند سرية في العقد، وسجلات جلسات 30 يوماً بلا مراجعة.

الاحتمال 4 «محتمل»: الاستغلال سهل متى عُرفت كلمة المرور، وهي مشتركة بين 5 أشخاص ولم تتغير منذ سنوات. لم نختر 5 لأن المهاجم يحتاج أولاً إلى كلمة المرور، ولا توجد ثغرة منشورة تتجاوزها.

الأثر 4 «عالٍ»: تسرب بيانات شخصية لعشرات الآلاف مع احتمال توقف الخدمة، بأثر كبير على رُفاد. لم نختر 5 لأن الأثر لا يمتد إلى المستوى الوطني.

المستوى 4 × 4 = 16 · عالٍ: معالجة إلزامية وعرض على اللجنة.

الإجابة: المعالجة

الخيار التخفيف، وعلى الخطر مالك واحد: مدير تقنية المعلومات.

الإجراء	المالك	الموعد
حسابات فردية لكل فني وإلغاء الحساب المشترك	مدير تقنية المعلومات	14 يوماً
تفعيل التحقق متعدد العوامل على أداة الوصول (ECC 2-2-3-2)	مدير تقنية المعلومات	14 يوماً
إيقاف الوصول الدائم: وصول عند الطلب بموافقة	مدير تقنية المعلومات	30 يوماً
مراجعة أسبوعية لسجلات الجلسات	مدير تقنية المعلومات	30 يوماً
إضافة بنود ECC 4-1-2 عند تجديد العقد	المدير المالي	عند التجديد

طلب التمرين ثلاثة إجراءات. أهمها: الحسابات الفردية، والتحقق متعدد العوامل، والوصول عند الطلب.

الإجابة: الخطر المتبقي والقرار

قبل المعالجة

4 × 4 = 16

عالٍ

←

المتبقي المتوقع

2 × 4 = 8

متوسط

لماذا بعد الإجراءات يصبح الاحتمال «نادراً» (2) لأن كلمة المرور وحدها لا تكفي. الأثر يبقى «عالياً» (4) لأن البيانات نفسها ما زالت على الخادم. النتيجة 8: «متوسط».

القرار المتوسط يحتاج قراراً: قبول موثق من الرئيس التنفيذي، أو معالجة إضافية مثل حصر الوصول بعناوين المورد المعتمدة.

التطبيق 2: أخطاء شائعة

لماذا الإجابة النموذجية أفضل

- «لا يوجد تحقق متعدد العوامل» ثغرة، وليست خطراً كاملاً. الخطر يربط الثغرة بحدث وأثر.
- كل درجة لها مبرر مأخوذ من أوصاف المصفوفة، لا من الانطباع.
- التحقق متعدد العوامل يقلل الاحتمال ولا يغير الأثر.
- المعالجة عند الخط الأول، وGRC يتابع، والمورد لا يملك الخطر.

أخطاء شائعة

- كتابة الثغرة وحدها خطراً: «لا يوجد MFA».
- درجات بلا تبرير، أو خلط الاحتمال بالأثر.
- افتراض أن الخطر يصبح «منخفضاً جداً» تلقائياً بعد أي ضابط.
- اختيار «النقل إلى المورد» معالجة؛ المسؤولية لا تنتقل.
- إجراءات بلا مالك أو موعد، أو مالكها GRC.

مخاطر الأطراف الخارجية: دورة حياة المورد

1
التخطيط
ما الخدمة، وما البيانات التي سيصل إليها؟

2
التقييم قبل التعاقد
استبيان وأدلة وتصنيف للمخاطر.

3
العقد
السرية، والإبلاغ، والالتزام بالسياسات، وحذف البيانات.

4
المتابعة
مراجعة دورية وتحديث التقييم.

5
الإنهاء
إعادة البيانات وحذفها، وإلغاء الصلاحيات.

⚠ في رُفاد: عقد سَنَد ينقصه الإبلاغ عن الحوادث والالتزام بسياسات رُفاد، وهما من بنود ECC 4-1-2.

استمرارية الأعمال: RTO وRPO

تحليل أثر الأعمال (BIA) يحدد أهم الخدمات، وكم تتحمل الجهة توقفها.



نظام الرواتب في رُفاد: RTO يوم عمل واحد، وRPO أربع ساعات. النسخة اليومية لا تكفي، فهذه فجوة تُكتب ملاحظة.

حماية البيانات الشخصية: الأساسيات

في المملكة: نظام حماية البيانات الشخصية (PDPL)، والجهة المختصة سدايا. دخل حيز النفاذ في 14 سبتمبر 2023.

- ✓ أساس نظامي لكل معالجة، وغرض محدد، وأقل قدر من البيانات.
- ✓ حقوق لصاحب البيانات، منها العلم والوصول والتصحيح والإتلاف.
- ✓ سجل لأنشطة المعالجة، وتقييم أثر للمعالجات عالية المخاطر.
- ✓ إبلاغ الجهة المختصة عن حوادث التسرب خلال المدة المحددة في اللوائح.

في رُفاد: بيانات الموظفين في نظام الرواتب، وبيانات المستلمين في تطبيق التتبع، كلاهما بيانات شخصية.

الجزء الثالث

الامتثال

هل نلتزم بما يجب، وكيف نثبت ذلك؟

المتطلب والضابط والدليل والنتيجة
النطاق والانطباق
التوثيق والتطبيق والتشغيل
الأدلة وكفايتها
العينات

تقييم ضابط كامل
التطبيق 3
الملاحظة وخطة التصحيح
التطبيق 4

المتطلب والضابط والدليل ونتيجة التقييم

المتطلب

ماذا يجب؟

ECC 2-2-3-5:
مراجعة دورية للصلاحيات.

←

الضابط

كيف تلتزم الجهة؟

مراجعة ربع سنوية لنظام الرواتب بمعيار معتمد.

←

الدليل

ما الذي يثبت؟

ملف المراجعة، والاعتماد، وتذاكر الإزالة.

←

نتيجة التقييم

إلى أي حد؟

مطبق، أو جزئياً، أو غير مطبق، أو لا ينطبق.

المتطلب واحد، والضابط اختيار الجهة لتحقيقه. لذلك قد تحقق جهتان المتطلب نفسه بضابطين مختلفين.

النطاق والانطباق قبل طلب الأدلة

قبل أن تطلب أي دليل، اتفق مكتوباً على النطاق. مثال: تقييم رُفاد الداخلي للنصف الأول من 2026.

السؤال	الإجابة في رُفاد
ما المتطلبات المنطبقة؟	ضوابط الهويات 3-2-2 كلها، و5-9-1.
ما الأنظمة ضمن النطاق؟	نظام الرواتب، والبريد، وVPN، وتطبيق التتبع.
ما الفترة؟	1 يناير إلى 30 يونيو 2026.
من مالك كل ضابط؟	سلمان للتقنية، ومنى لنظام الرواتب.
ما المستثنى ولماذا؟	خادم تجريبي معزول بلا بيانات حقيقية: «لا ينطبق» بمبرر موثق.

⚠ دليل خارج الفترة أو خارج النطاق لا يُحتسب، مهما كان جيداً.

موثق، ومطبق، ويعمل باستمرار

موثق

هل المتطلب مكتوب ومعتمد؟

دليله: سياسة أو معيار معتمد.

مطبق

هل الإعداد أو الإجراء موجود فعلاً؟

دليله: تصدير إعداد من النظام بتاريخه.

يعمل باستمرار

هل عمل طوال الفترة ولكل النطاق؟

دليله: سجلات وملفات تغطي الفترة كاملة.

سياسة موجودة لا تثبت إعداداً، وإعداد اليوم لا يثبت ما حدث في الأشهر الماضية.

الأدلة: الأنواع، وكيف تحكم على كفايتها

أنواع الأدلة

- وثائق معتمدة: سياسات، ومحاضر
- تصدير من النظام: إعدادات وقوائم
- سجلات وتقارير: ما حدث فعلاً
- مقابلات وملاحظة مباشرة
- إعادة التنفيذ: تجرب الضابط بنفسك

هل يكفي الدليل؟ اسأل:

- مرتبط: هل يجيب عن هدف الفحص؟
- موثوق: ما مصدره؟ من النظام أم نسخة معدّلة؟
- كافٍ: هل يغطي الفترة والمجتمع؟
- مؤرخ: هل يقع داخل الفترة؟

لا يوجد ترتيب ثابت لقوة الأدلة. المقابلة تساعدك على الفهم، والسجلات قد تكون ناقصة. القيمة تعتمد على هدف الفحص ومصدر الدليل وتغطيته.

المجتمع والعينة وحدود الاستنتاج

المجتمع والعينة

- ✓ المجتمع: كل الحالات في الفترة، مثل 41 حساب VPN.
- ✓ إن أمكن تصديره كاملاً، افحصه كاملاً.
- ✓ العينة: جزء مختار بطريقة معروفة، عشوائياً أو بمعيار مبرر.

حدود الاستنتاج

- ⚠ نتيجة العينة تخص ما فحصته، والتعميم يحتاج مبرراً.
- ⚠ استثناءان من حساب واحد لا يعنيان أن كل الحسابات ضعيفة.
- ⚠ السبب الجذري يُتحقق منه، ولا يُستنتج من بريد أو انطباع.

تقييم ضابط كامل: ثمانية عناصر

1 المتطلب
النص ورقمه

2 التفسير
ماذا يعني في الجهة

3 المالك
من يطبق الضابط

4 الأدلة
ما طلبته وما وصل

5 طريقة الفحص
كيف اختبرت كل دليل

6 النتيجة
من مقياس محدد

7 الملاحظة
إن وُجدت فجوة

8 خطة التصحيح
إجراء، ومالك، وموعد

في مثال التطبيق 3 نعبئ هذه العناصر لضابط من رُفاد، ثم تعبئها أنت لضابط آخر.

مقياس نتيجة التقييم

النتيجة	المعنى
مطبق	المتطلب موثق ومطبق، ويعمل باستمرار طوال فترة التقييم.
مطبق جزئياً	جزء من المتطلب مطبق، أو طُبق في جزء من الفترة فقط.
غير مطبق	لا دليل على التطبيق، أو الأدلة تنفي التطبيق.
لا ينطبق	المتطلب خارج النطاق، بمبرر موثق.

⚠ المقاييس تختلف بين الجهات والجهات المنظمة. استخدم دائماً مقياس الجهة التي تقيّمها.

مثال محلول: المتطلب والنطاق

المتطلب ECC 2-2-3-2: التحقق متعدد العوامل للدخول عن بعد وللحسابات ذات الصلاحيات الهامة.

النطاق والفترة دخول الموظفين عن بعد عبر الشبكة الافتراضية VPN. الفترة: 1 يناير إلى 30 يونيو 2026. الحسابات ذات الصلاحيات الهامة تُقيّم منفصلة.

المالك مدير تقنية المعلومات

حددنا النطاق والفترة قبل طلب أي دليل.

مثال محلول: الأدلة المستلمة

الدليل	ما وصل
د1	معيار الوصول عن بعد، معتمد فبراير 2026: التحقق متعدد العوامل إلزامي لكل مستخدمي VPN.
د2	لقطة إعداد من بوابة VPN بتاريخ 5 يوليو 2026: التحقق إلزامي لمجموعة «VPN-Users».
د3	سجل تغييرات الإعداد: فُعّل الإلزام في 10 مارس 2026.
د4	أعضاء مجموعة «VPN-Users»: 38 حساباً. سجل الاتصالات: 41 حساباً اتصلت خلال الفترة.
د5	عينة 25 اتصالاً بعد 10 مارس: 23 بعامل ثانٍ، و2 بكلمة المرور فقط، كلاهما من حساب «test».

قبل أن تنتقل: ماذا يثبت كل دليل؟ وهل تكفي لقطة 5 يوليو؟

مثال محلول: الفحص والنتيجة

سؤال الفحص	ما وجدناه
هل المتطلب موثق؟	نعم: د1 يغطي المتطلب.
هل الإعداد مطبق، ومنذ متى؟	نعم منذ 10 مارس (د3). اللقطة د2 بعد الفترة، فلا تكفي وحدها.
هل يعمل طوال الفترة ولكل المستخدمين؟	لا: لا إلزام قبل 10 مارس، و3 حسابات خارج المجموعة (د4، د5).

النتيجة

مطبق جزئياً

المتطلب موثق ومطبق على المجموعة الرئيسية منذ 10 مارس، لكنه لم يعمل في أول الفترة، وتوجد 3 حسابات تتصل دون عامل ثانٍ.

لا نعمم العينة: الاتصالان الضعيفان من حساب واحد. مقارنة المجتمع كاملاً (41 مقابل 38) حددت الحسابات الثلاثة بدقة.

دورك: مراجعة صلاحيات نظام الرواتب

المتطلب ECC 2-2-3-5: المراجعة الدورية لهويات الدخول والصلاحيات.

النطاق والفترة نظام الموارد البشرية والرواتب. الفترة: 1 يناير إلى 30 يونيو 2026 (ربعان).

المعيار المعتمد معيار التحكم بالوصول، معتمد 15 يناير 2026: مراجعة كل 3 أشهر، واعتماد خلال 10 أيام عمل، وإزالة خلال 5 أيام عمل.

هذا الضابط هو الذي كتبنا بنده في التطبيق 1. الآن نفحص: هل التزمت به رُفاد فعلاً؟

دورك: الأدلة المستلمة

الدليل	ما وصل
د1	معيار التحكم بالوصول المعتمد في 15 يناير 2026.
د2	ملف مراجعة الربع الأول: تصدير 29 مارس، 214 حساباً، اعتمدته مالكة النظام في 8 أبريل، و12 حساباً للإزالة.
د3	تذاكر الإزالة: 9 حسابات أزيلت حتى 12 أبريل، و3 أزيلت في 20 مايو.
د4	لا ملف لمراجعة الربع الثاني. بريد من تقنية المعلومات: «تأجلت بسبب ترحيل النظام إلى إصدار جديد في يونيو».
د5	تصدير الحسابات النشطة في 2 يوليو: 221 حساباً، منها حسابان لموظفين غادروا في مايو.
د6	مقابلة مع مالكة النظام: «نراجع الصلاحيات عندما يطلب المدير».

انتبه للتواريخ ولمهلة كل خطوة في المعيار.

دورك: المطلوب والنموذج

لكل دليل: ماذا يثبت؟ ثم النتيجة ومبررها، وما ستطلبه قبل الإغلاق. 20 دقيقة.

الدليل	ماذا يثبت؟
د1	
د2	
د3	
د4	
د5	
د6	

النتيجة

مطبق / جزئياً / غير مطبق / لا ينطبق

المبرر

ثلاث جمل...

أدلة إضافية

ماذا ستطلب؟

الإجابة: ماذا يثبت كل دليل؟

الدليل	ماذا يثبت
د1	التوثيق: المتطلب موثق ومعتمد.
د2	التطبيق: المراجعة نُفذت واعتُمدت في موعدها للربع الأول.
د3	الاستمرار: 3 إزالات متأخرة عن مهلة 5 أيام عمل.
د4	الاستمرار: الربع الثاني لم يُنفذ. السبب ادعاء لم نتحقق منه بعد.
د5	نتيجة فعلية: صلاحيات غير مبررة بقيت نشطة.
د6	لا تثبت شيئاً وحدها، لكنها تكشف فجوة وعي بالمعيار.

الإجابة: النتيجة ومبررها

النتيجة
مطبق جزئياً

المتطلب موثق (د1) وطُبق في الربع الأول (د2)، لكنه لم يعمل باستمرار: الربع الثاني لم يُنفذ (د4)، و3 إزالات تأخرت (د3)، وبقيت صلاحيات غير مبررة (د5). اختيار «مطبق» يتجاهل نصف الفترة، واختيار «غير مطبق» يتجاهل ما نُفذ فعلاً.

أدلة إضافية قبل الإغلاق

- ✓ سجل تغيير ترحيل النظام لتأكيد التاريخ وهل منع المراجعة فعلاً.
- ✓ هل اعتُمد استثناء بتأجيل المراجعة وموعد بديل؟
- ✓ هل نُفذت مراجعة الربع الثاني لاحقاً في يوليو؟
- ✓ سبب تأخر الإزالات الثلاث من تذاكرها.

التطبيق 3: أخطاء شائعة

القاعدة التي تمنعها

- ابحث عن دليل لكل مستوى: موثق، ومطبق، ويعمل.
- النتيجة تعكس الفترة كاملة.
- المقابلة تفتح سؤالاً ولا تغلقه.
- التعميم يحتاج مبرراً.
- السبب يُتحقق منه بدليل.

أخطاء شائعة

- «مطبق» لأن المعيار موجود: الوثيقة لا تثبت التشغيل.
- «غير مطبق» مع تجاهل الربع الأول.
- الاعتماد على المقابلة وحدها دليلاً.
- تعميم: «كل الإزالات متأخرة» من 3 حالات من 12.
- اعتبار سبب البريد مؤكداً دون تحقق.

الملاحظة: خمسة عناصر

الوضع القائم
ما وجدته، بأرقام وتواريخ.

المعيار
المتطلب أو البند الذي يُقاس عليه.

السبب
لماذا حدث، بعد التحقق.

الأثر
ماذا يعني للجهة، بلغة العمل.

التوصية
ما يعالج السبب، لا العَرَض فقط.

اكتب الحقائق لا الأحكام: «3 من 41 حساباً»، لا «بعض الحسابات». ولا تلُم أشخاصاً، صف العملية.

خطة التصحيح: إجراء، ومالك، وموعد، ودليل

الإجراء
ما الذي سيُنفذ تحديداً؟

المالك
شخص واحد بالوظيفة.

الموعد
تاريخ، لا «قريباً».

دليل الإغلاق
ما الذي يثبت الإنجاز؟

إجراء فوري يزيل الخطر الآن، وإجراء دائم يمنع التكرار.

لا تُغلق الملاحظة بوعد. تُغلق بدليل، وبعد إعادة الاختبار.

إن قررت الإدارة قبول الخطر بدل التصحيح، يوثق القرار صاحب الصلاحية. وهذا لا يلغي أي التزام نظامي.

مثال محلول: الملاحظة

العنوان	حسابات تتصل بالشبكة عن بعد دون تحقق متعدد العوامل
الوضع القائم	لم يكن التحقق متعدد العوامل مفروضاً على اتصالات VPN حتى 10 مارس 2026. وبعد التفعيل، اتصلت 3 حسابات من 41 من خارج مجموعة التحقق، منها حساب لمستشار انتهى عقده.
المعيار	ECC 2-2-3-2، ومعيار الوصول عن بعد في رُفاد (فبراير 2026).
السبب	أُضيفت الحسابات الثلاثة يدوياً استثناءً «مؤقتاً» عند التفعيل، دون إجراء موافقة أو مراجعة. تحققنا من ذلك بسجل التغييرات ومقابلة فريق تقنية المعلومات.
الأثر	من يعرف كلمة مرور أحد الحسابات الثلاثة يستطيع دخول الشبكة الداخلية دون عامل ثانٍ، ومنها حساب لشخص لم يعد يعمل مع رُفاد.
التوصية	إزالة الاستثناءات الثلاثة، واعتماد إجراء للاستثناءات بموافقة ومدة ومراجعة، ومطابقة دورية بين مستخدمي VPN ومجموعة التحقق. التفاصيل في خطة التصحيح.

مثال محلول: خطة التصحيح

الإجراء	المالك	الموعد	دليل الإغلاق
تعطيل حساب المستشار السابق	مدير تقنية المعلومات	يوم عمل واحد	تصدير يبين الحساب معطلاً، وسجل التغيير
نقل الحسابين إلى مجموعة التحقق أو تعطيلهما	مدير تقنية المعلومات	5 أيام عمل	تصدير المجموعة، وسجل VPN لأسبوع
اعتماد إجراء استثناءات بموافقة ومدة ومراجعة	مسؤولة GRC	30 يوماً	الإجراء المعتمد، وسجل الاستثناءات
مطابقة شهرية: مستخدمو VPN مقابل المجموعة	مدير تقنية المعلومات	بدءاً من الشهر القادم	تقارير 3 أشهر متتالية

الإجراء الأول فوري يزيل الخطر الأكبر. الثالث والرابع يمنعان التكرار.

دورك: ملاحظة وخطة تصحيح لنظام الرواتب

1. اكتب ملاحظة بعناصرها الخمسة لنتيجة التطبيق 3 (مراجعة صلاحيات نظام الرواتب).
2. السبب: افترض أنك تحققت من سجل الترحيل ووجدت أنه لم يُعتمد أي استثناء لتأجيل المراجعة.
3. اكتب خطة تصحيح من 4 إجراءات: المالك، والموعد، ودليل الإغلاق.

نتيجتك في التطبيق 3: مطبق جزئياً

- ✓ الربع الأول نُفذ واعتُمد في موعده.
- ✓ الربع الثاني لم يُنفذ حتى 30 يونيو.
- ✓ 3 من 12 إزالة تأخرت عن مهلة 5 أيام عمل.
- ✓ في 2 يوليو: حسابان لمغادرين في مايو ما زالا نشطين.

دورك: النموذج

العنوان	
الوضع القائم	أرقام وتواريخ...
المعيار	
السبب	ما تحققت منه...
الأثر	
التوصية	ما يعالج السبب

وجدول خطة التصحيح في الكراسة: الإجراء، والمالك، والموعد، ودليل الإغلاق. 20 دقيقة.

الإجابة: الملاحظة

العنوان	عدم انتظام المراجعة الدورية لصلاحيات نظام الموارد البشرية والرواتب
الوضع القائم	نُفذت مراجعة الربع الأول واعتُمدت في موعدها، لكن 3 من 12 إزالة نُفذت بعد 6 أسابيع، ولم تُنفذ مراجعة الربع الثاني حتى 30 يونيو 2026. وفي 2 يوليو كان حسابان لموظفين غادروا في مايو ما زالا نشطين.
المعيار	ECC 2-2-3-5، ومعيار التحكم بالوصول (يناير 2026): مراجعة كل 3 أشهر، وإزالة خلال 5 أيام عمل.
السبب	أُجّلت مراجعة الربع الثاني بسبب ترحيل النظام دون استثناء معتمد أو موعد بديل، ولا توجد متابعة لتذاكر الإزالة المتأخرة. تحققنا من ذلك بسجل الترحيل وتذاكر الإزالة.
الأثر	بقاء صلاحيات غير مبررة على رواتب الموظفين وحساباتهم البنكية، منها حسابان لمغادرين.
التوصية	تعطيل حسابي المغادرين فوراً، وإكمال مراجعة الربع الثاني، واعتماد جدول مراجعات ببديل معتمد عند التعارض، ومتابعة تذاكر الإزالة. التفاصيل في خطة التصحيح.

الإجابة: خطة التصحيح وإعادة الاختبار

الإجراء	المالك	الموعد	دليل الإغلاق
تعطيل حسابي المغادرين ومراجعة نشاطهما بعد المغادرة	مدير تقنية المعلومات	يوما عمل	تصدير الحسابات، ونتيجة مراجعة السجل
تنفيذ مراجعة الربع الثاني واعتمادها	مديرة الموارد البشرية	15 يوم عمل	ملف المراجعة المعتمد، وتذاكر الإزالة
جدول مراجعات سنوي بتذكير آلي وبديل معتمد عند التعارض	مديرة الموارد البشرية	30 يوماً	الجدول المعتمد، وإعداد التذكير
متابعة أسبوعية لتذاكر الإزالة المفتوحة	مدير تقنية المعلومات	فوراً	تقرير التذاكر الأسبوعي

تعيد GRC الاختبار بعد مراجعة الربع الثالث، ولا تُغلق الملاحظة إلا بأدلة الإغلاق.

التطبيق 4: أخطاء شائعة

ما يجعل الإجابة قوية

- الوضع القائم أرقام وتواريخ، لا أحكام عامة.
- السبب مُتحقق منه، ويعالج العملية لا الأشخاص.
- كل إجراء له مالك واحد باسم الوظيفة، وموعد، ودليل إغلاق.
- إجراء فوري لإزالة الخطر، وإجراءات تمنع التكرار.

أخطاء شائعة

- لوم شخص بالاسم بدل العملية.
- مالك عام: «تقنية المعلومات» أو «الجميع».
- إجراء بلا موعد أو دليل إغلاق.
- الاكتفاء بتوصية «تدريب الموظفين».
- إغلاق الملاحظة بوعد بدل دليل.

الصورة كاملة: كيف ترتبط الحلقات في رُفاد

قرار
التحقق متعدد العوامل إلزامي
الشريحة 19

←

سياسة
بند المراجعة الدورية
الشريحة 31

←

خطر
حساب المورد المشترك
الشريحة 53

←

ضابط
مراجعة ربع سنوية
الشريحة 61

دليل
ملفات المراجعة والتذاكر
الشريحة 72

←

ملاحظة
مراجعة غير منتظمة
الشريحة 83

←

تصحيح
إجراءات بمالك وموعد
الشريحة 84

هذه هي GRC في جهة واحدة: كل حلقة تعتمد على التي قبلها. والتطبيقات الأربعة غطت الحلقات كلها.

03

الأطر والانطباق

لا تحتاج أن تحفظ كل الأطر. تحتاج أن تعرف ماذا يفعل كل منها، ولمن هو، وكيف تحدد ما ينطبق على الجهة.

بعد هذه الوحدة ستستطيع أن:

- تفرق بين النظام والضابط والإطار والمعيار، وبين الملزم والاختياري.
- تعرف ISO 27001 وNIST CSF 2.0 والأطر السعودية الأساسية.
- تحدد ما ينطبق على جهة بأربعة أسئلة، وتبدأ بالإطار المناسب.

نظام، وضوابط، وإطار، ومعيار: ما الفرق؟

النوع	هل هو ملزم؟	مثال
نظام أو تشريع	ملزم بقوة القانون لمن يقع في نطاقه	نظام حماية البيانات الشخصية
ضوابط تنظيمية	ملزمة للجهات التي يحددها نطاقها	ECC-2:2024 للجهات المشمولة
إطار	يرشد ويرتب العمل، وغالباً طوعي	NIST CSF 2.0
معيار قابل للشهادة	طوعي، تُمنح عليه شهادة من جهة مانحة	ISO/IEC 27001
التزام تعاقدي	ملزم بالعقد لا بالقانون	PCI DSS عبر العقود مع شبكات البطاقات

السؤال الأول دائماً: هل هذا المرجع ملزم لهذه الجهة تحديداً، أم اختارته طوعاً؟

خريطة الأطر العالمية (1 من 2)

نظام إدارة يُمنح شهادة

كيف ندير الأمن باستمرار؟

ISO/IEC 27001
أمن المعلومات

ISO 22301
استمرارية الأعمال

ISO/IEC 27701
إدارة الخصوصية

أطر مخاطر وضوابط

ماذا نطبق، وبأي ترتيب؟

NIST CSF 2.0
لغة مشتركة لإدارة المخاطر

NIST SP 800-53
كتالوج ضوابط تفصيلي

CIS Controls
ضوابط مرتبة بالأولوية

خريطة الأطر العالمية (2 من 2)

حوكمة التقنية

هل تخدم التقنية أهداف الجهة؟

COBIT 2019
من ISACA: أهداف حوكمة وإدارة

COSO
الرقابة الداخلية وإدارة المخاطر المؤسسية

قطاعية وتعاقدية

ماذا يطلب القطاع أو العميل؟

PCI DSS v4.0.1
لمن يعالج بيانات البطاقات

SOC 2
تقرير تأكيد لمزودي الخدمات

GDPR
حماية البيانات في أوروبا

الأطر تتداخل. ضابط واحد، مثل التحقق متعدد العوامل، يحقق متطلبات في عدة أطر معاً. ربطها يسمى «المواءمة».

ISO/IEC 27001:2022: البنود الإلزامية

4
السياق والنطاق

5
القيادة والسياسة

6
التخطيط وتقييم المخاطر

7
الدعم والموارد

8
التشغيل ومعالجة المخاطر

9
تقييم الأداء والتدقيق الداخلي

10
التحسين المستمر

مسار الشهادة تدقيق المرحلة 1 للوثائق، ثم المرحلة 2 للتطبيق، ثم شهادة لثلاث سنوات مع تدقيق متابعة سنوي.

ISO/IEC 27001: الملحق A وبيان قابلية التطبيق

الملحق A: 93 ضابطاً في 4 محاور



بيان قابلية التطبيق (SoA)

لا تطبق كل الضوابط تلقائياً. تختار ما يلزم من تقييم المخاطر، وتوثق المطبق والمستبعد ومبرر كل منهما.

المعيار المرافق ISO/IEC 27002 يشرح كل ضابط بالتفصيل.

NIST CSF 2.0: ست وظائف، والحوكمة في المركز

GV

الحوكمة · Govern · جديدة في 2.0

الاستراتيجية، والأدوار، والسياسات، ومخاطر سلسلة الإمداد. هنا يعمل GRC مباشرة.

ID
التحديد
الأصول والمخاطر

PR
الحماية
الهويات والبيانات والمنصات

DE
الاكتشاف
المراقبة وتحليل الأحداث

RS
الاستجابة
إدارة الحادثة

RC
التعافي
استعادة العمليات

NIST CSF: المستويات والملفات التعريفية

المستويات تصف مدى صرامة ممارسات الجهة في حوكمة مخاطر الأمن السيبراني وإدارتها، من استجابة غير رسمية إلى نهج متكيف ومستمر التحسين.

1
جزئي
Partial

2
مطلع على المخاطر
Risk Informed

3
قابل للتكرار
Repeatable

4
متكيف
Adaptive

كيف تُستخدم

- ✓ تختارها القيادة للجهة كلها، أو لوظيفة أو فئة.
- ✓ توجه الملفين الحالي والمستهدف.
- ✓ الانتقال لمستوى أعلى عند حاجة المخاطر أو الالتزامات.

ما ليست عليه

- ⚠ ليست درجة نضج لكل ضابط.
- ⚠ لا تحل محل منهجية إدارة المخاطر.
- ⚠ لا يُشترط أن تكون كل جهة في المستوى 4.

الأطر السعودية: ضوابط الهيئة الوطنية للأمن السيبراني

الضوابط	موضوعها ونطاقها المختصر
ECC-2:2024	الضوابط الأساسية: 108 ضوابط للجهات الحكومية والتابعة لها وجهات البنية التحتية الوطنية الحساسة
CCC-2:2024	الحوسبة السحابية: لمقدمي الخدمات السحابية والمستفيدين منها
DCC-1:2022	البيانات: حمايتها في دورة حياتها
CSCC-1:2019	الأنظمة الحساسة الوطنية
OTCC-1:2022	أنظمة التقنية التشغيلية والتحكم الصناعي
TCC-1:2021	العمل عن بعد
OSMACC-1:2021	حسابات التواصل الاجتماعي للجهات

الضوابط الأخرى امتداد لـ ECC في سياقات محددة. النطاق الدقيق في النص الرسمي لكل منها.

الأطر السعودية: مراجع أخرى تهمك

المرجع	الجهة	لمن
الإطار الوطني لإدارة مخاطر الأمن السيبراني NFCRM-1:2025	الهيئة الوطنية للأمن السيبراني	نطاق ECC نفسه
إطار ساما للأمن السيبراني، الإصدار 1.0 (2017)	البنك المركزي السعودي	الجهات المالية الخاضعة لإشرافه
نظام حماية البيانات الشخصية ولوائحه	سدايا	من يعالج بيانات شخصية في المملكة
معايير إدارة البيانات وحماية البيانات الشخصية v1.5	مكتب إدارة البيانات الوطنية	الجهات العامة وشركاؤها
الإطار السعودي لكوادر الأمن السيبراني SCyWF-1.5:2026	الهيئة الوطنية للأمن السيبراني	الأدوار الوظيفية ومهامها

للمسار المهني: SCyWF فيه فئة «الحوكمة والمخاطر والامتثال والأنظمة» بأدوارها. استخدم أسماءها في سيرتك.

كيف تحدد ما ينطبق على الجهة؟ أربعة أسئلة

1 نوع الجهة

حكومية، أم تابعة لجهة حكومية، أم تملك بنية حساسة، أم خاصة؟

2 القطاع والمنظم

هل تخضع لجهة رقابية قطاعية، مثل البنك المركزي؟

3 نوع البيانات

بيانات شخصية؟ بيانات بطاقات؟ بيانات حكومية؟

4 العقود والعملاء

هل تفرض العقود متطلبات أمن على الجهة؟

ثم تحقق من نص «نطاق التطبيق» في المرجع الرسمي نفسه. لا تحكم من اسم الإطار.

تمرين: ما الذي ينطبق على كل جهة؟

رُفاد شركة خاصة للتوصيل، تعالج بيانات موظفين ومستلمين، لا تعالج بيانات بطاقات بنفسها.

شركة «مدى التقنية» شركة افتراضية تابعة لوزارة، تقدم خدمات تقنية للوزارة.

شركة «دفع سريع» شركة تقنية مالية افتراضية مرخصة من البنك المركزي السعودي، تعالج مدفوعات بالبطاقات.

الجهة	ECC-2:2024	نظام حماية البيانات الشخصية	إطار ساما للأمن السيبراني	PCI DSS
رُفاد				
شركة «مدى التقنية»				
شركة «دفع سريع»				

لكل خانة: نعم، أو لا، أو يعتمد، مع سبب قصير. 10 دقائق.

الإجابة: الانطباق على الجهات الثلاث

الجهة	ECC-2:2024	نظام حماية البيانات الشخصية	إطار ساما للأمن السيبراني	PCI DSS
رُفاد	غير ملزم؛ تبنته طوعاً	نعم	لا	لا، ما دامت لا تخزن بيانات البطاقات أو تعالجها أو تنقلها
مدى التقنية	نعم: تابعة لجهة حكومية	نعم إن عالجت بيانات شخصية	لا	حسب معالجتها للبطاقات
دفع سريع	لا، ما لم تكن حكومية أو بنية تحتية حساسة	نعم	غالباً نعم: تحقق من نطاق الإطار في دليل ساما	نعم: تعالج بيانات البطاقات

الإجابة: قاعدة الانطباق والأخطاء الشائعة

ما يجعل الإجابة قوية

- الانطباق يُحدَّد من النص الرسمي لنطاق كل إطار، لا من اسمه.
- النوع (حكومي أو خاص)، والقطاع، ونوع البيانات، والعقود: أربعة أسئلة تكفي للبداية.
- الإطار غير الملزم يمكن تبنيه طوعاً، لكن لا تصف الجهة بأنها «ملتزمة نظاماً» به.

أخطاء شائعة

- ⚠ افتراض أن ECC تلزم كل شركة سعودية.
- ⚠ نسيان نظام حماية البيانات الشخصية لأن الجهة ليست تقنية.
- ⚠ الجزم بالانطباق دون الرجوع إلى نص النطاق.

بأي إطار تبدأ؟ وكيف تقرؤه؟

1

NIST CSF 2.0

مجاني، ويعطيك الصورة الكاملة.

2

ISO/IEC 27001

منطق نظام الإدارة، وكثير الطلب.

3

إطار قطاعك

حكومي: ECC. بنوك: SAMA CSF. مدفوعات: PCI DSS.

مع كل ضابط تقرؤه، اسأل:

1. ما الخطر الذي يعالجه؟
2. كيف يبدو تطبيقه في جهة حقيقية؟
1. ما الدليل الذي يثبت تطبيقه؟
2. ما الذي يقابله في إطار آخر؟

04 الشهادات

أي شهادة تناسب هدفك ومرحلتك؟ ماذا تعلّمك، وهل تشترط خبرة، ومتى تدرسها؟

بعد هذه الوحدة ستستطيع أن:

- تعرف الشهادات الأهم في GRC والأمن والخصوصية، ولمن تناسب كل منها.
- تفرق بين شهادة التدريب، والنجاح في الاختبار، واللقب المهني.
- تختار مسارك حسب الوظيفة المستهدفة، وتعرف كيف تذاكر.

خريطة الشهادات: ثلاث مراحل

البداية

بلا خبرة: تثبت الأساسيات.

ISC2	**CC**
CompTIA	**Security+**
ISACA	**IT Risk Fund.**

التخصص

مهارة محددة في GRC أو معيار.

ISO 27001 LI/LA	جهات مانحة
GRCP	OCEG
CIPP/E · CIPM	IAPP

بعد اكتمال الخبرة

تُمنح بعد سنوات خبرة موثقة.

CRISC · CISA · CISM	ISACA
CGRC · CISSP	ISC2
CGEIT · CDPSE	ISACA

شهادات البداية: CC وSecurity+

ISC2 CC

Certified in Cybersecurity

لمن؟	خريج أو متحول بلا خبرة.
ماذا تعلّم؟	مبادئ الأمن، والحوكمة الأمنية، والهويات، والشبكات والسحابة، والعمليات.
الخبرة	لا تشترط خبرة.
متى؟	الآن: أول شهادة.

CompTIA Security+

CompTIA Security+

لمن؟	من يريد أساساً تقنياً أعمق.
ماذا تعلّم؟	التهديدات، والمعمارية، والعمليات، وإدارة البرنامج الأمني.
الخبرة	لا شرط رسمي؛ يُنصح بخبرة سنتين.
متى؟	الآن أو بعد CC، حسب خلفيتك.

⚠ انتهى عرض اختبار CC المجاني من ISC2: أُغلق التسجيل فيه في 20 مايو 2026.

مدخل إلى GRC والمخاطر: GRCP وIT Risk Fundamentals

OCEG GRCP

GRC Professional

لمن؟ من يريد أساساً في GRC نفسه.

ماذا تعلّم؟ مفاهيم GRC ونموذج OCEG للقدرات.

الخبرة لا تشترط خبرة.

متى؟ مبكراً، بعد الأساسيات.

ISACA IT Risk Fundamentals

IT Risk Fundamentals Certificate

لمن؟ مبتدئ يتجه إلى مخاطر التقنية.

ماذا تعلّم؟ أساسيات مخاطر تقنية المعلومات.

الخبرة لا شرط. شهادة إتمام، لا اعتماد مهني.

متى؟ الآن.

ISO 27001: منفذ رئيسي أم مدقق رئيسي؟

Lead Implementer PECB وجهات أخرى

ISO/IEC 27001 Lead Implementer

لمن؟	من سيبني نظام إدارة أمن المعلومات أو يستشير فيه.
ماذا تعلّم؟	تخطيط النظام وتطبيقه ومتابعته وفق البنود 4 إلى 10.
الخبرة	الاختبار بلا خبرة، واللقب يحتاج خبرة.
متى؟	إن اتجهت للتطبيق والاستشارات.

Lead Auditor PECB وجهات أخرى

ISO/IEC 27001 Lead Auditor

لمن؟	من سيدقق أنظمة الإدارة داخلياً أو لدى جهة مانحة.
ماذا تعلّم؟	تخطيط التدقيق وتنفيذه، وكتابة الملاحظات وإعداد التقرير.
الخبرة	الاختبار بلا خبرة، واللقب يحتاج خبرة تدقيق.
متى؟	إن اتجهت للتدقيق.

لا تصدرها ISO نفسها، بل جهات تدريب واعتماد مثل PECB وBSI. شروط كل جهة تختلف.

شهادات ISO: التدريب ليس الاختبار، والاختبار ليس اللقب

1

إتمام التدريب

شهادة حضور أو إتمام. عند PECB: 31 ساعة تطوير مهني.

←

2

النجاح في الاختبار

عند PECB: 80 سؤالاً بكتاب مفتوح، والنجاح 70%.

←

3

استحقاق اللقب

Provisional بلا خبرة، ثم Implementer، ثم Lead، ثم Senior Lead.

←

4

متطلبات الجهة

كل جهة مانحة لها شروطها. شهادة PECB تختلف عن غيرها.

قد تجد دورات تُشرح بالعربية، لكن لغة الاختبار شيء آخر. تحقق منها في قائمة اختبارات الجهة.

شهادات ISO: من الاختبار إلى اللقب المهني

اللقب عند PECB	الخبرة	ساعات المشاريع
Provisional Implementer	لا شيء	لا شيء
Implementer	سنتان، منها سنة في إدارة أمن المعلومات	200
Lead Implementer	5 سنوات، منها سنتان في إدارة أمن المعلومات	300
Senior Lead Implementer	10 سنوات، منها 7 في إدارة أمن المعلومات	1000

⚠ إن كتبت في سيرتك Lead Implementer، فتأكد أنك تستحق اللقب، لا أنك حضرت الدورة فقط.

ISACA (1 من 2): التدقيق والمخاطر

ISACA CISA

Certified Information Systems Auditor

لمن؟	تدقيق تقنية المعلومات: الخط الثالث.
ماذا تعلّم؟	عملية التدقيق، وحوكمة التقنية، وتشغيل الأنظمة وحمايتها.
الخبرة	5 سنوات، وإعفاء حتى 3.
متى؟	بعد خبرة تدقيق. تستطيع الاختبار مبكراً.

ISACA CRISC

Risk and Information Systems Control

لمن؟	مخاطر التقنية: الخط الثاني.
ماذا تعلّم؟	الحوكمة، وتقييم المخاطر، والاستجابة والتقارير، والتقنية.
الخبرة	3 سنوات في مجالين من 4، بلا إعفاء.
متى؟	بعد سنتين أو ثلاث في المخاطر.

في ISACA تستطيع الاختبار أولاً، ثم تقديم طلب الشهادة خلال 5 سنوات من النجاح حين تكتمل الخبرة.

ISACA (2 من 2): الإدارة والحوكمة

ISACA CISM

Certified Information Security Manager

لمن؟	من يتجه لإدارة برنامج الأمن.
ماذا تعلّم؟	من 3 نوفمبر 2026: الحوكمة 18%، والمخاطر 20%، والبرنامج 33%، والحوادث 29%.
الخبرة	5 سنوات في 3 مجالات من 4، وإعفاء حتى سنتين.
متى؟	حين تتجه للإدارة.

ISACA CGEIT

Governance of Enterprise IT

لمن؟	قيادات حوكمة التقنية.
ماذا تعلّم؟	حوكمة تقنية المعلومات على مستوى الجهة.
الخبرة	5 سنوات، بلا إعفاء.
متى؟	مرحلة متقدمة.

ISC2: الحوكمة والمخاطر، ثم القيادة

ISC2 CGRC

Governance, Risk and Compliance

لمن؟	محللو GRC ومديروه.
ماذا تعلّم؟	7 مجالات في GRC وإدارة مخاطر الأنظمة.
الخبرة	سنتان في مجال واحد من 7. بلا خبرة: Associate ومهلة 3 سنوات.
متى؟	بعد سنة أو سنتين في GRC.

ISC2 CISSP

Systems Security Professional

لمن؟	قيادة الأمن.
ماذا تعلّم؟	8 مجالات واسعة، منها الأمن وإدارة المخاطر بنسبة 16%.
الخبرة	5 سنوات في مجالين من 8. بلا خبرة: Associate ومهلة 6 سنوات.
متى؟	بعد سنوات. ليست شهادة GRC خالصة.

Associate of ISC2: تنجح قبل اكتمال الخبرة، ثم تُمنح الشهادة حين تكتمل خلال المهلة.

الخصوصية (1 من 2): شهادتا IAPP

IAPP CIPP/E

Information Privacy Professional/Europe

لمن؟	قانونيون ومختصو حماية بيانات مرتبطون بأوروبا.
ماذا تعلّم؟	قانون حماية البيانات في أوروبا.
الخبرة	لا شرط مذكور.
متى؟	إن ارتبط عملك بأوروبا، أو أردت أساساً قانونياً.

IAPP CIPM

Certified Information Privacy Manager

لمن؟	من يدير برنامج الخصوصية في جهة.
ماذا تعلّم؟	بناء برنامج الخصوصية وتشغيله، غير مرتبطة بقانون دولة واحدة.
الخبرة	لا شرط مذكور.
متى؟	مناسبة للعمل على الخصوصية عملياً.

الخصوصية (2 من 2): CDPSE، وكيف تختار

ISACA CDPSE

Data Privacy Solutions Engineer

لمن؟ الجانب التقني للخصوصية.

ماذا تعلّم؟ هندسة الخصوصية في الأنظمة ودورة حياة البيانات.

الخبرة 3 سنوات، بلا إعفاء.

متى؟ بعد خبرة في الخصوصية.

قبل أن تختار

- لـ CIPP ستة تركيزات إقليمية: آسيا، وأستراليا، وكندا، والصين، وأوروبا، والولايات المتحدة.
- لا توجد بينها شهادة خاصة بالنظام السعودي.
- في السعودية الأساس نظام حماية البيانات الشخصية ولوائحه. الشهادة الدولية تبني عليه ولا تغني عنه.

المقارنة: كم سنة خبرة تحتاج؟

0 بلا خبرة

- CC
- Security+
- IT Risk Fund.
- GRCP
- CIPP/E · CIPM
- ISO Provisional

2 سنتان

- CGRC
- ISO Implementer

3 سنوات

- CRISC
- CDPSE

5 سنوات

- CISA
- CISM
- CGEIT
- CISSP
- ISO Lead

الخبرة المطلوبة قبل منح الشهادة، مع الإعفاءات المتاحة. الرسوم والتجديد في الملحق: الشريحة 155.

كيف تختار: ابدأ من الوظيفة، لا من الشهادة

الوظيفة المستهدفة	مدخل	تخصص	بعد اكتمال الخبرة
محلل GRC وامتثال الخط الثاني	CC أو Security+	ISO 27001 LI أو GRCP	CRISC أو CGRC
مدقق تقنية معلومات الخط الثالث	CC أو IT Audit Fund.	ISO 27001 LA	CISA
الخصوصية وحماية البيانات مثل مسؤول حماية البيانات	CC	CIPM أو CIPP/E	CDPSE
قيادة الأمن والحوكمة هدف بعيد	أي مسار مما سبق	CISM أو CISSP	CGEIT

☆ شهادة واحدة لكل مرحلة. ما بين المراحل خبرة ومشاريع، لا شهادة إضافية.

لغة التدريب ولغة الاختبار

لغة التدريب ليست لغة الاختبار

- ✓ قد تجد دورة تُشرح بالعربية، والاختبار بالإنجليزية.
- ✓ تحقق من لغة الاختبار في صفحة الجهة المانحة قبل الحجز.
- ✓ بعض الجهات تمنح وقتاً إضافياً لمن يختبر بغير لغته الأم.

الاختبار	العربية؟
ISC2: CC وCISSP	لا عربية. CGRC: الإنجليزية فقط
ISACA: الشهادات الخمس	لا عربية. اللغات تختلف لكل شهادة
CompTIA Security+	لا عربية في الإصدار الحالي
IAPP: CIPP/E وCIPM	لا عربية
PECB وOCEG وIT Risk Fund.	لم نتحقق. راجع صفحة الجهة

القائمة الكاملة للغات كل اختبار في الملحق: الشريحتان 158 و159.

كيف تذاكر لأي شهادة: أربع خطوات

1
مخطط الاختبار

Exam Outline مجاني. المجالات وأوزانها خطتك.

←

2
مصدر أساسي واحد

الدليل الرسمي أو دورة معتمدة.

←

3
بنك أسئلة بفهم

لماذا الصحيح صحيح، والباقي خطأ.

←

4
احجز حين تثبت درجاتك

تتجاوز حد النجاح مرة بعد مرة.

فكّر كمدير: أسئلة ISACA وISC2 تسأل عن «الأفضل» أو «الأول» من منظور المخاطر.

طابق مادتك مع مخطط يوم اختبارك: CC وCISM وSecurity+ وCISSP تتغير بين 2026 و2027.

تمرين: اختر الشهادة المناسبة

سارة خريجة نظم معلومات، بلا خبرة، تريد وظيفة محللة امتثال خلال سنة.

عبدالله محاسب بخبرة 4 سنوات في المراجعة الداخلية، يريد التحول إلى تدقيق تقنية المعلومات.

نورة محامية بخبرة سنتين، مهتمة بحماية البيانات الشخصية.

لكل شخص: شهادة الآن، وشهادة لاحقاً، وسبب من جملتين. 8 دقائق.

الإجابة: اقتراحات للأشخاص الثلاثة

الشخص	الاقتراح	لماذا
سارة	ISO 27001 Lead Implementer أو GRCP. CRISC أو CGRC الآن، ثم CC أو Security+ لاحقاً بعد اكتمال الخبرة.	شهادة مدخل بلا شرط خبرة، ثم مهارة تطبيقية مطلوبة في الإعلانات.
عبدالله	ISO 27001 Lead Auditor أو IT Audit Fundamentals الآن، وCISA هدفاً قريباً.	خبرته في المراجعة قد تُحتسب لشرط CISA بحسب قواعد ISACA، فتحقق منها. Lead Auditor يبني على مهارة التدقيق لديه.
نورة	CIPP/E أو CIPM الآن، مع قراءة نظام حماية البيانات الشخصية ولوائحه.	خلفيتها القانونية تناسب CIPP/E، وCIPM يضيف إدارة برنامج الخصوصية. لا تحتاج شهادة تقنية أولاً.

05 خطة البداية وملف الأعمال

الخبرة أكبر عائق للمبتدئ. هنا تحول تطبيقات الكورس إلى دليل على قدرتك قبل أول وظيفة.

بعد هذه الوحدة ستستطيع أن:

- تحول التطبيقات الأربعة إلى مشاريع منشورة.
- تبني خطة 90 يوماً واقعية.
- تكتب صفحة تعريفية لكل مشروع.

خطة 90 يوماً: من الصفر إلى أول طلب توظيف

على أساس 8 إلى 10 ساعات أسبوعياً تقريباً. عدّلها حسب وقتك.

الأساس

الأيام 1 إلى 30

- ✓ الوحدات 1 إلى 3 والتطبيقات الأربعة
- ✓ قراءة NIST CSF 2.0
- ✓ بدء مذاكرة شهادة مدخل

المخرَج: تطبيقات مصححة في الكراسة.

التطبيق

الأيام 31 إلى 60

- ✓ مشروعان من الشريحة التالية
- ✓ قراءة إطار قطاعك
- ✓ حجز اختبار الشهادة

المخرَج: مشروعان منشوران بصفحتين تعريفيتين.

السوق

الأيام 61 إلى 90

- ✓ السيرة ولينكدإن
- ✓ طلبات أسبوعية ومحادثات تعريفية
- ✓ خمس قصص STAR

المخرَج: طلبات مقدمة واستعداد للمقابلة.

من تطبيق صغير إلى مشروع في ملف أعمالك

ما نفذته في الكورس	المشروع الأكبر لملف أعمالك
1. مسؤوليات وبند سياسة	حزمة: سياسة ومعيار وإجراء لموضوع واحد
2. خطر واحد	سجل مخاطر من 10 مخاطر، ثم 20
3. تقييم ضابط	تقييم مكوّن فرعي كامل من ECC، مثل 2-2
4. ملاحظة وخطة تصحيح	تقرير تدقيق مصغر من 3 ملاحظات
مخاطر الأطراف الخارجية	استبيان تقييم مورد وتحليل ردوده
الأطر	مصفوفة مواءمة: ECC مقابل ISO 27001 وNIST CSF

⚠ رُفاد، أو جهة افتراضية مثلها، دائماً. لا تنشر وثائق أو بيانات من جهة حقيقية، حتى لو تدربت فيها.

صفحة تعريفية لكل مشروع

صفحة واحدة في بداية كل مشروع: يقرؤها مسؤول التوظيف في دقيقة.

عنوان المشروع	سجل مخاطر مصغر لشركة لوجستية افتراضية
المشكلة	لا يوجد سجل مخاطر، والإدارة لا تعرف أين تبدأ.
ما فعلته	حددت 10 مخاطر، وقيمتها بمصفوفة NFCRM، واقترحت معالجة لكل خطر عالٍ.
النتيجة	3 مخاطر عالية بخطط ومالكين ومواعيد.
ما تعلمته	الضابط يغير الاحتمال أو الأثر، لا الاثنين دائماً.
الملفات	السجل، وصفحة المنهجية. بيانات افتراضية.

المهارات المطلوبة، وكيف تتدرب عليها

مهارات المجال

قراءة الأطر	الأسئلة الأربعة مع كل ضابط
تقييم المخاطر	التطبيق 2 ثم مشروع السجل
فحص الأدلة	التطبيق 3
أساسيات تقنية	الهويات والشبكات والسحابة
Excel	الجداول المحورية والتنسيق الشرطي

مهارات شخصية، وغالباً هي الفارق

الكتابة الواضحة	ملاحظة في 3 أسطر بدل 10
شرح التقني لغير التقني	خطر في دقيقة لصديق
الإقناع	اربط التوصية بأثر على العمل
المتابعة	مالك وموعد لكل شيء
النزاهة والسرية	لا مجاملة، ولا إفشاء

🌐 والإنجليزية: أغلب المعايير والاختبارات بها. اقرأ يومياً ولو صفحة.

تمرين: صفحة مشروع تقييم الصلاحيات

اكتب صفحة تعريفية لمشروعك من التطبيقين 3 و4: تقييم مراجعة الصلاحيات في رُفاد.

عنوان المشروع

المشكلة

ما فعلته

النتيجة

ما تعلمته

الملفات المرفقة

10 دقائق.

الإجابة: صفحة المشروع

عنوان المشروع تقييم مراجعة الصلاحيات في نظام الرواتب، شركة افتراضية

المشكلة معيار يطلب مراجعة ربع سنوية، ولا نعرف هل تُنفذ فعلاً.

ما فعلته حللت 6 أدلة، وحددت نتيجة «مطبق جزئياً»، وكتبت ملاحظة وخطة تصحيح بأربعة إجراءات.

النتيجة ملاحظة واحدة بمالكين ومواعيد وأدلة إغلاق، و4 أسئلة متابعة قبل الإغلاق.

ما تعلمته وجود المعيار لا يثبت التشغيل، والسبب يحتاج تحققاً قبل كتابته.

الملفات المرفقة ورقة التقييم، ونص الملاحظة، وخطة التصحيح. كلها ببيانات افتراضية.

06

السيرة الذاتية

سيرة تقرؤها الأنظمة والبشر، وتقول «أستطيع أن أفعل» لا «أنا مهتم».

بعد هذه الوحدة ستستطيع أن:

- تبني سيرة من صفحة واحدة بالترتيب المناسب للمبتدئ.
- تكتب إنجازات بالمعادلة: فعل، ثم ماذا، ثم كيف، ثم النتيجة.
- تتجنب الأخطاء الشائعة، وتصوغ خبرتك السابقة بلغة GRC.

تشريح سيرة مبتدئ (1 من 2): الرأس والملخص والمهارات

Sara Ahmed

Entry-Level GRC Analyst | Risk · Control Testing 1

Riyadh · sara.ahmed@email.com · linkedin.com/in/sara-ahmed-grc

---

SUMMARY 2

Entry-level GRC analyst with hands-on risk assessment and control testing projects. ISC2 CC.

SKILLS 3

Risk Assessment · Control Testing · ISO 27001 · NIST CSF · NCA ECC · Excel

الجزء الأعلى من سيرة من صفحة واحدة. الاسم والبيانات مثال.

1. العنوان: مسمى الوظيفة التي تستهدفها.
2. ملخص في سطرين: من أنت، وماذا تجيد.
3. المهارات بكلمات الإعلان نفسها، إن كانت صادقة عنك.

تشريح سيرة مبتدئ (2 من 2): المشاريع والتعليم والشهادات

PROJECTS 4

Vendor Access Risk · Fictional 200-staff company

• Rated a vendor remote-access risk High (16); proposed 5 actions with owners.

Access Review Assessment · Same company

• Tested 6 evidence items; wrote a finding with a 4-step corrective plan.

EDUCATION

B.Sc. Information Systems, 2025

CERTIFICATIONS 5

ISC2 CC, 2026

4 المشاريع قبل التعليم إن لم تكن لديك خبرة.

5 الشهادات باسمها والسنة. «قيد الدراسة» مع موعد مقبولة.

صفحة واحدة للمبتدئ. بلا صورة ولا عمر ولا حالة اجتماعية، إلا إن طلبها الإعلان.

بقية الصفحة نفسها.

أنظمة الفرز (ATS): البسيط أضمن

1 ترسل السيرة ← **2** يستخرج النظام النص ← **3** يقارن بالإعلان ← **4** يرتب أو يصفّي ← **5** يقرأ إنسان

يقلل احتمال الخطأ

- ✓ ملف نصي، لا صورة ممسوحة
- ✓ عناوين قياسية: Experience وSkills
- ✓ مصطلحات الإعلان إن كانت صادقة عنك
- ✓ عمود واحد ومعلومات الاتصال في المتن

قد يسبب مشكلة في بعض الأنظمة

- ⚠ نصوص داخل صور أو مربعات نص
- ⚠ جداول وأعمدة معقدة
- ⚠ أشرطة تقييم المهارات
- ⚠ حشو كلمات لا تعرفها

الأنظمة تختلف كثيراً، وبعضها يقرأ التنسيقات المعقدة جيداً. البسيط أضمن، لا أكثر.

صياغة الإنجاز: قبل وبعد

فعل قوي + ماذا فعلت + بأي طريقة + النتيجة أو الرقم

AFTER

Built a 5-activity RACI for leaver access revocation and wrote a policy clause with owner, deadline and evidence.

BEFORE

Responsible for the RACI matrix.

AFTER

Wrote and scored a payroll-laptop risk on the NCA 5×5 matrix (12, Medium) and planned encryption with a 30-day due date.

BEFORE

Did risk assessment.

الأرقام في سيرتك يجب أن تكون حقيقية: ستُسأل عن كل رقم.

بلا خبرة في GRC؟ خبرتك أقرب مما تظن

ترجم خلفيتك إلى لغة GRC

الدعم الفني	طلبات الصلاحيات، وسير الموافقات، والبلاغات
المحاسبة والتدقيق	الرقابة الداخلية، والأدلة، والعينات
القانون	الأنظمة واللوائح، والعقود، والخصوصية
إدارة الجودة	أنظمة الإدارة، والتدقيق الداخلي، والإجراءات
إدارة المشاريع	متابعة المعالجة بمالك وموعد، وتقارير الحالة

أقسام تملأ مكان الخبرة

- ✓ Projects: مشاريع الوحدة 5
- ✓ Internship: التدريب التعاوني
- ✓ Volunteering: سياسة لجمعية
- ✓ Capstone: مشروع التخرج

ستة أخطاء شائعة، وتصحيح كل منها

الخطأ	التصحيح
سيرة من ثلاث صفحات لمبتدئ	صفحة واحدة
«Responsible for...» في كل سطر	فعل، ثم ماذا، ثم كيف، ثم النتيجة
أخطاء إملائية في وظيفة تقوم على الدقة	مدقق إملائي، ثم قراءة شخص آخر
نسخة واحدة لكل الإعلانات	عدّل الملخص والمهارات للإعلان المهم
شهادة لم تحصل عليها	ما حصلت عليه، أو «قيد الدراسة» مع موعد
رقم الهوية أو الجواز في السيرة	الاسم والمدينة ووسائل التواصل تكفي

تمرين: أعد صياغة ثلاثة أسطر

أعد صياغة كل سطر بالمعادلة، مستخدماً ما نفذته في التطبيقات 2 و3 و1.

السطر الضعيف	صياغتك
Responsible for risk assessment.	
Helped with access review.	
Familiar with NCA ECC.	

بالإنجليزية، وبأرقام حقيقية من تطبيقاتك. 8 دقائق.

الإجابة: ثلاثة أسطر بعد إعادة الصياغة

قبل	بعد
Responsible for risk assessment.	Assessed a vendor remote-access risk for a fictional 200-staff company; rated it High (16) and proposed 5 actions with owners and dates.
Helped with access review.	Tested a quarterly access review against 6 evidence items; rated it partially implemented and wrote a finding with a 4-step corrective plan.
Familiar with NCA ECC.	Mapped ECC-2:2024 controls 2-2-3-2 and 2-2-3-5 to evidence requests and test steps for a training case.

كل سطر يبدأ بفعل، ويذكر الطريقة، وينتهي بنتيجة أو رقم من عملك الفعلي على حالة تدريبية.

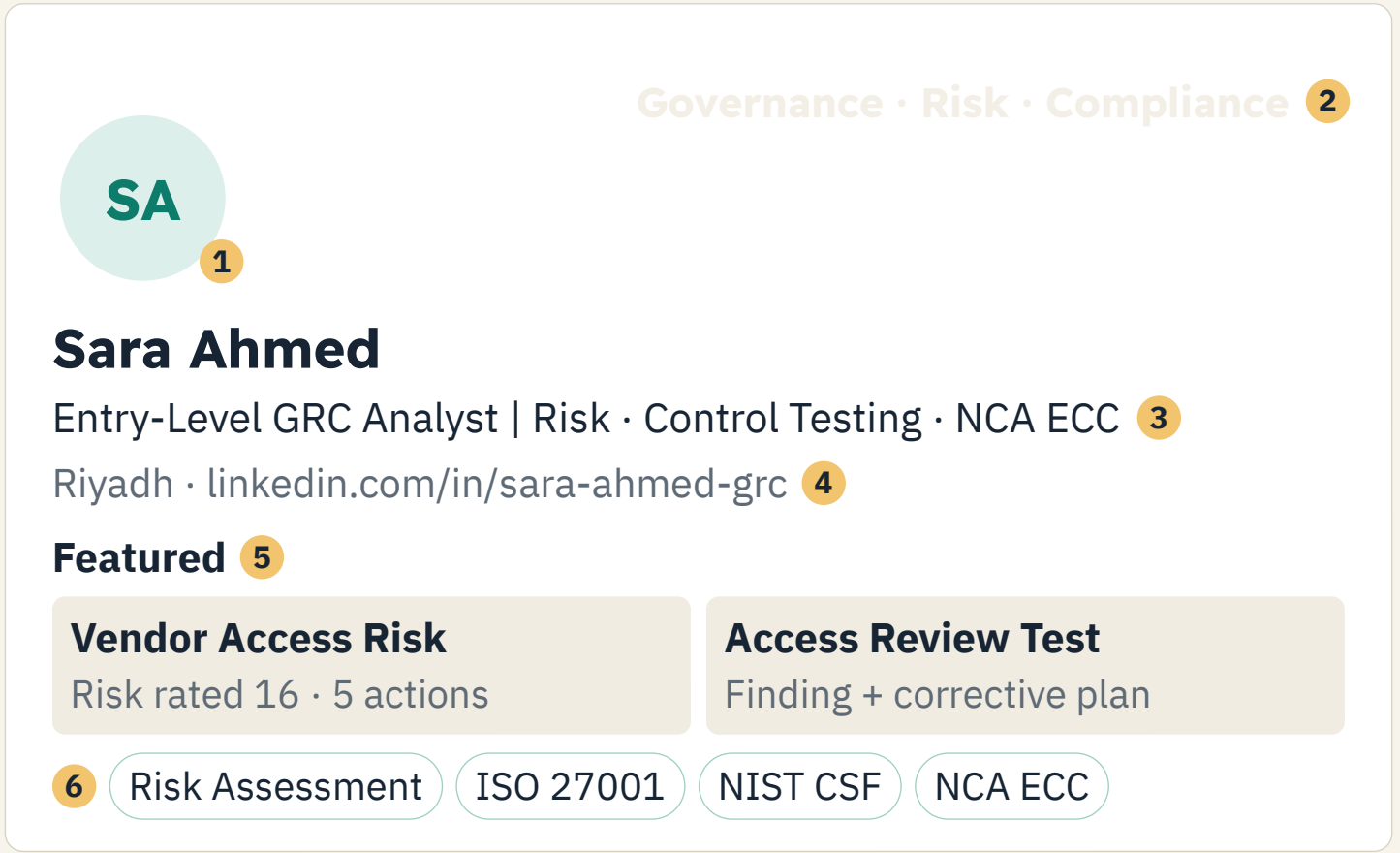
07 لينكدإن والفرص

ملفك يعمل وأنت نائم: يجده مسؤول التوظيف حين يبحث، ويقرؤه قبل أن يتصل بك.

بعد هذه الوحدة ستستطيع أن:

- تكمل ملفك: الصورة، والعنوان، والنبذة، وقسم Featured.
- تبني شبكة وتنشر بطريقة آمنة ومهنية.
- تستخدم Open to Work والبحث بأكثر من مسمى.

تشريح ملف مكتمل



1. الصورة: من 400×400 بكسل، حتى 8 ميغابايت، JPG أو PNG.
2. الخلفية: المقاس الموصى به 1584×396 بكسل.
3. العنوان المهني: الوظيفة المستهدفة وكلماتها.
4. رابط مخصص: من 3 إلى 100 حرف، بلا مسافات أو رموز.
5. Featured: مشاريعك أعلى الملف.
6. المهارات: حتى 100 مهارة. أهمها في الأعلى.

العنوان المهني: أهم سطر في ملفك

الوظيفة المستهدفة | مجالان أو ثلاثة | دليل: شهادة أو مشروع

قوي

Entry-Level GRC Analyst | Risk Assessment · ISO 27001 · NCA ECC | ISC2 CC

IT Support → GRC | Access Management · NIST CSF 2.0 | Security+

محلل حوكمة ومخاطر وامتثال | ECC · ISO 27001 | مشروعا تقييم

ضعيف

Computer Science Student

Looking for opportunities

Cybersecurity enthusiast | Hard worker

لم نجد حداً رسمياً لعدد الحروف في صفحات المساعدة. ضع أهم الكلمات في البداية.

نبذة About: أربعة أجزاء في فقرات قصيرة

About

Entry-level GRC analyst focused on turning requirements into clear, testable controls.

In a training case for a 200-staff company, I rated a vendor access risk and tested a quarterly access review, then wrote a finding with a corrective plan.

Focus: risk assessment · control testing · ISO/IEC 27001 · NIST CSF 2.0 · NCA ECC · ISC2 CC.

Open to entry-level GRC and compliance roles in Riyadh. See my projects in Featured.

1. الافتتاح
من أنت، وما تركيزك.

2. الدليل
مشروعان بنتائج محددة.

3. المجالات والأطر
كلمات البحث.

4. الدعوة
ماذا تبحث عنه، وكيف يتواصلون معك.

الحد 2,600 حرف، لكن 150 إلى 250 كلمة تكفي غالباً.

الشبكة والنشر: كن مرئياً في مجالك

من تضيف، وكيف

- مختصو GRC في الجهات التي تستهدفها
- مسؤولو التوظيف في الأمن السيبراني
- زملاء الدراسة والدورات والفعاليات

> «أ. نورة، استفدت من منشورك عن تقييم الموردين. أنا في بداية مساري في GRC، ويسعدني التواصل.»

ماذا تنشر

1. ضابط واحد بمثال من الواقع
2. مشروع من ملف أعمالك وما تعلمته
3. خلاصة فعالية حضرتها
4. تعليق مفيد على منشور مختص

⚠ لا تنشر أي تفصيل عن ضوابط أو ثغرات جهة عملت أو تدربت فيها.

البحث عن الفرص: Open to Work والمسميات

فعّل Open to Work

Me → View profile → Open to → Finding a new job

كل الأعضاء يراه الجميع، ويضيف إطار #OpenToWork.

مسؤولو التوظيف فقط لا تضمن LinkedIn إخفاءه تماماً عن جهتك الحالية.

ابحث بأكثر من مسمى

GRC Analyst

Cybersecurity Compliance

IT Risk Analyst

IT Auditor

Security Controls Assessor

Cybersecurity Policy Officer

محلل حوكمة ومخاطر

- تنبيه وظائف لكل مسمى، وقدّم مبكراً.
- قدّم أيضاً من مواقع الجهات مباشرة.

تمرين: عنوانك وافتتاح نبذتك

العنوان المهني

الوظيفة | مجالان أو ثلاثة | دليل

افتتاح النبذة

جملتان: من أنت، وأقوى دليل من مشاريعك

بالإنجليزية، ومن مشاريعك الفعلية. 8 دقائق.

الإجابة: عنوان وافتتاح نموذجيان

العنوان

Entry-Level GRC Analyst | Risk Assessment · Control Testing · NCA ECC | ISC2 CC

الافتتاح

Entry-level GRC analyst who turns requirements into clear, testable controls. In a training case for a 200-staff company, I rated a vendor access risk, tested an access review, and wrote a finding with a corrective plan.

كلمات البحث في البداية، ودليل حقيقي، ولا مبالغة: «training case» تقول الحقيقة وتحميك في المقابلة.

08 المقابلة والانطلاق

كل ما تعلمته يُختبر في ساعة واحدة. استعد لها كما تستعد لاختبار الشهادة.

بعد هذه الوحدة ستستطيع أن:

- تجيب عن الأسئلة المتوقعة بأمثلة من رُفاد.
- تحكي قصصك بطريقة STAR.
- تنطلق بخطة واضحة لما بعد الكورس.

ثمانية أسئلة متوقعة، وأين جوابها

«ما الفرق بين التهديد والثغرة والخطر؟»
يختبر: المفاهيم — 39

«كيف تقيّم خطراً وترتبه؟»
يختبر: المصفوفة والمبرر — 44

«ما الفرق بين السياسة والمعيار والإجراء؟»
يختبر: هرم الوثائق — 25

«كيف تتأكد أن ضابطاً مطبق فعلاً؟»
يختبر: الأدلة والفترة — 63

«مالك نظام يرفض تطبيق ضابط. ماذا تفعل؟»
يختبر: الإقناع والبدائل — 146

«ما الفرق بين الامتثال والمراجعة الداخلية؟»
يختبر: الخطوط الثلاثة — 24

«اشرح ECC أو ISO 27001 لمدير غير تقني»
يختبر: التبسيط — 95

«لماذا GRC؟ ولماذا جهتنا؟»
يختبر: دافعك وبحثك — جهّزه بنفسك

إجابة نموذجية: مالك نظام يرفض الضابط

السؤال: «مالك نظام يرفض تطبيق ضابط. ماذا تفعل؟» مثال من رُفاد: سلمان يرفض فرض التحقق على حساب المورد خوفاً من تعطل الدعم.

1. **افهم السبب:** «ما الذي يمنع التطبيق؟ تكلفة، أم تعطّل عمل، أم سوء فهم؟»
2. **اشرح الخطر بلغة العمل:** «حساب مشترك بلا تحقق قد يكشف بيانات 50 ألف مستلم.»
3. **اقترح بديلاً:** ضابط تعويضي، أو تطبيق مرحلي بموعد.
4. **إن تعذر: استثناء موثق:** مؤقت، بموافقة صاحب الصلاحية، ومراجعة دورية.
5. **التصعيد آخر خطوة:** للجنة، بالحقائق لا بالشكوى.

ما يقيسه السؤال: هل تعالج الخلاف بفهم المخاطر والعلاقة، لا بالمادة والنص فقط؟

طريقة STAR: قصة قصيرة بنتيجة واضحة

السؤال: «حدثنا عن مرة حللت فيها مشكلة معقدة.» مثال محلول من التطبيق 2.

S الموقف

في مشروع تدريبي، كان لمورد الدعم حساب إداري مشترك على أداة مكشوفة.

T المهمة

تقييم الخطر واقتراح معالجة.

A ما فعلته أنا

كتبت الخطر، وقيمته بمصفوفة الهيئة مع مبرر كل درجة، واقترحت 5 إجراءات بمالكين ومواعيد.

R النتيجة

خطر عالٍ (16) بخطة تنزله إلى متوسط، وقرار مطلوب من الإدارة للباقي.

دقيقة إلى دقيقتين

«أنا» في الإجراء، لا «نحن»

جهّز 5 قصص مسبقاً

تمرين: قصتك بطريقة STAR

السؤال: «حدثنا عن مرة اكتشفت فيها مشكلة في ضابط ولم يكن الدليل واضحاً.»

S الموقف

T المهمة

A ما فعلته أنا

R النتيجة

استخدم التطبيقين 3 و4. 8 دقائق.

الإجابة: قصة STAR نموذجية

S	**الموقف**	في مشروع تدريبي لشركة افتراضية، كان المطلوب تقييم مراجعة الصلاحيات الفصلية في نظام الرواتب.
T	**المهمة**	تحديد نتيجة التقييم من 6 أدلة متفاوتة.
A	**ما فعلته أنا**	ربطت كل دليل بما يثبته، فوجدت أن الربع الثاني لم يُنفذ وأن حسابين لمغادرين بقيا نشطين، ثم طلبت سجل الترحيل للتحقق من السبب بدل الاعتماد على البريد.
R	**النتيجة**	قيّمت الضابط «مطبقاً جزئياً» وكتبت ملاحظة بخطة تصحيح من 4 إجراءات، ونشرت المشروع في ملف أعمالي.

قائمة المراجعة: هل أنت جاهز للتقديم؟

المعرفة

- ☐ أشرح مصطلحات المخاطر بمثال
- ☐ أفرق بين السياسة والمعيار والإجراء
- ☐ أعرف ما ينطبق على قطاعي

التطبيق

- ☐ أنهيت التطبيقات الأربعة وصححتها
- ☐ مشروعان منشوران بصفحتين
- ☐ لا بيانات لجهة حقيقية

الشهادة

- ☐ اخترت شهادة مدخل واحدة
- ☐ قرأت مخطط اختبارها الحالي
- ☐ تحققت من الرسوم واللغة

السوق

- ☐ سيرة صفحة واحدة بإنجازات
- ☐ ملف لينكدإن مكتمل
- ☐ 5 قصص STAR جاهزة

نهاية الكورس، وبداية المسار

ابدأ هذا الأسبوع بثلاث خطوات

لا تنتظر أن تكتمل الصورة. خطوة كل أسبوع، ودليل تراه أنت وغيرك.

الأسعار والشروط والإصدارات كما في 27 أكتوبر 2026. تحقق منها قبل التسجيل.

1 **اختر شهادة المدخل**
واقرأ مخطط اختبارها الرسمي

2 **وسّع التطبيق 2**
إلى سجل من 10 مخاطر

3 **حدّث عنوانك في لينكدإن**
بالمعادلة من الشريحة 138

الملحق المرجعي

جداول وأرقام تتغير، فصلناها عن الدروس لتحدّثها بسهولة: القاموس، ورسوم الشهادات، وصيغ الاختبارات ولغاتها، والمراجع السعودية، والروابط.

الملحق المرجعي · مرجع قابل للتحديث

القاموس (1 من 2)

سجل المخاطر Risk Register
قائمة المخاطر بالمالك والدرجة والمعالجة

شهية المخاطر Risk Appetite
حجم الخطر الذي تقبله الجهة عموماً

حدود التحمل Risk Tolerance
حدود قابلة للقياس لخطر أو مؤشر

الخطر المتأصل Inherent Risk
قبل تنفيذ خطط المعالجة

الخطر المتبقي Residual Risk
بعد احتساب خطط المعالجة

مؤشر المخاطر الرئيسي KRI
رقم ينبه مبكراً إلى ارتفاع خطر

تقييم الفجوات Gap Assessment
مقارنة الوضع القائم بمتطلبات مرجع

بيان قابلية التطبيق SoA
ضوابط ISO 27001 المطبقة والمستبعدة ولماذا

مالك الضابط Control Owner
من يطبق الضابط ويحتفظ بأدلته

القاموس (2 من 2)

ضابط تعويضي Compensating Control
بديل يحقق الهدف حين يتعذر الأصلي

استثناء Policy Exception
إعفاء داخلي موثق ومؤقت من متطلب

فصل المهام SoD
لا ينفذ شخص واحد العملية ويعتمدها

أقل صلاحية Least Privilege
صلاحيات بقدر حاجة العمل فقط

العناية الواجبة Due Diligence
التحقق من المورد قبل التعاقد

المجتمع والعينة Population / Sample
كل الحالات، وجزء مختار منها

الملاحظة Finding
فجوة بين الوضع القائم والمعيار

خطة التصحيح Corrective Action Plan
إجراء ومالك وموعد ودليل إغلاق

تحليل أثر الأعمال BIA
أهم الخدمات وكم تتحمل الجهة توقفها

الملحق المرجعي · مرجع قابل للتحديث

رسوم الشهادات وتجديدها (1 من 2)

الشهادة	رسم الاختبار (دولار)	المحافظة والتجديد (دولار)
CC · ISC2	199	50 سنوياً، و45 ساعة CPE كل 3 سنوات
CGRC · ISC2	599	135 سنوياً، و60 ساعة CPE كل 3 سنوات
CISSP · ISC2	749	135 سنوياً، و120 ساعة CPE كل 3 سنوات
CISA · CISM · CRISC · CGEIT · CDPSE	575 للأعضاء، 760 لغيرهم، و50 للطلب	45 أو 85 سنوياً، و120 ساعة CPE كل 3 سنوات
IT Risk / Audit Fundamentals · ISACA	175 للأعضاء، 225 لغيرهم	لم تذكره الصفحة
Security+ · CompTIA	لم نتحقق: يُعرض حسب الدولة	50 وحدة CEU و150 كل 3 سنوات

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل. المصادر في الملاحظات.

الملحق المرجعي مرجع قابل للتحديث

رسوم الشهادات وتجديدها (2 من 2)

الشهادة	رسم الاختبار (دولار)	المحافظة والتجديد
CIPP/E · CIPM · IAPP	550 للأعضاء وغيرهم	250 كل سنتين و20 ساعة CPE، أو عضوية 295 سنوياً
GRCP · OCEG	ضمن اشتراك 499 أول سنة، ثم 399	مع الاشتراك. الصفحة تذكر قاعدتين متعارضتين
ISO 27001 LI/LA · PECB	حسب مقدم التدريب. بلا تدريب: 1,000 للاختبار و500 للطلب	كل 3 سنوات بساعات CPD ورسم سنوي لم نتحقق من قيمته

⚠ سعر إعادة اختبار IAPP كان 375 دولاراً في دليل 2022، ولم نتحقق من السعر الحالي.

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

صيغ الاختبارات: الأسئلة والمدة والنجاح

الشهادة	الأسئلة والمدة	النجاح
CC	100 إلى 125 · ساعتان · تكيفي	700 من 1000
CGRC	125 · 3 ساعات	700 من 1000
CISSP	100 إلى 150 · 3 ساعات · تكيفي	700 من 1000
Security+	حتى 90 · 90 دقيقة	750 من 900
IT Risk Fund.	غير مذكور · ساعتان	65%
GRCP	100 محتسبة · 120 دقيقة	70 سؤالاً

الشهادة	الأسئلة والمدة	النجاح
CISA · CISM	150 · 4 ساعات	450 من 800
CRISC · CGEIT	150 · 4 ساعات	450 من 800
CDPSE	120 · 3.5 ساعة	450 من 800
CIPP/E · CIPM	90 · ساعتان ونصف	300 من 500
PECB ISO 27001	80 · كتاب مفتوح	70%

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

لغات الاختبارات (1 من 2): ISC2 وCompTIA وIAPP

الاختبار	لغات الاختبار
CC	الإنجليزية، الصينية، اليابانية، الألمانية، الإسبانية
CISSP	الإنجليزية، الصينية، الألمانية، اليابانية، الإسبانية
CGRC	الإنجليزية فقط
Security+ SY0-701	الإنجليزية، اليابانية، البرتغالية، الإسبانية، التايلندية
CIPP/E	الإنجليزية، الفرنسية، الألمانية
CIPM	الإنجليزية، الفرنسية، الألمانية، البرتغالية البرازيلية، الصينية المبسطة

لغة الاختبار تختلف عن لغة التدريب. تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

لغات الاختبارات (2 من 2): ISACA وغيرها

الاختبار	لغات الاختبار
CISA	الإنجليزية، الإسبانية، الصينية المبسطة، الفرنسية، الألمانية، الكورية، اليابانية
CISM	الإنجليزية، الإسبانية، الصينية المبسطة، اليابانية، الفرنسية، الألمانية
CRISC	الإنجليزية، الإسبانية، اليابانية
CGEIT	الإنجليزية، الصينية المبسطة
CDPSE	الإنجليزية فقط
GRCP · IT Risk Fund. · PECB	غير مذكورة في الصفحات التي راجعناها

لم نجد العربية في أي من الاختبارات التي تحققنا منها. تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي · مرجع قابل للتحديث

المراجع السعودية (1 من 2): ضوابط الهيئة وإطار المخاطر

المرجع والإصدار	الجهة	النطاق المختصر
ECC-2:2024	الهيئة الوطنية للأمن السيبراني	الجهات الحكومية والتابعة، والبنية التحتية الوطنية الحساسة
NFCRM-1:2025	الهيئة الوطنية للأمن السيبراني	نطاق ECC نفسه
CCC-2:2024 · DCC-1:2022 · CSCC-1:2019	الهيئة الوطنية للأمن السيبراني	امتداد لـ ECC في سياقات محددة
OTCC-1:2022 · TCC-1:2021 · OSMACC-1:2021	الهيئة الوطنية للأمن السيبراني	امتداد لـ ECC في سياقات محددة

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

المراجع السعودية (2 من 2): الكوادر وساما وحماية البيانات

المرجع والإصدار	الجهة	النطاق المختصر
SCyWF-1.5:2026	الهيئة الوطنية للأمن السيبراني	الأدوار الوظيفية ومهامها
SAMA CSF 1.0 (2017)	البنك المركزي السعودي	الجهات الخاضعة لإشرافه
نظام حماية البيانات الشخصية	سدايا	نافذ منذ 14 سبتمبر 2023

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

روابط: الأطر والمراجع

الهيئة الوطنية للأمن السيبراني	nca.gov.sa
الإطار الوطني لإدارة المخاطر NFCRM	صفحة الإطار
الضوابط الأساسية ECC	صفحة الضوابط
الإطار السعودي لكوادر الأمن السيبراني	صفحة SCyWF
إطار ساما للأمن السيبراني	rulebook.sama.gov.sa
NIST CSF 2.0	nist.gov/cyberframework
دليل NIST لاستخدام Tiers	SP 1302
ISO/IEC 27001	iso.org

الملحق المرجعي مرجع قابل للتحديث

روابط: الشهادات

ISC2: الشهادات	isc2.org/certifications
ISC2: أسعار الاختبارات	صفحة الأسعار
ISACA: الشهادات	isaca.org/credentialing
ISACA: تحديث مخطط CISM	البيان الصحفي 2026
CompTIA Security+	comptia.org
IAPP	iapp.org/certify
OCEG GRCP	oceg.org
PECB	pecb.com

الملحق المرجعي مرجع قابل للتحديث

روابط: الخصوصية والقطاعات ولينكدإن

دليل سدايا لنظام حماية البيانات الشخصية	dgp.sdaia.gov.sa
PCI DSS: مكتبة الوثائق	pcisecuritystandards.org
COBIT	isaca.org/resources/cobit
LinkedIn: Open to Work	صفحة المساعدة
LinkedIn: الرابط المخصص	صفحة المساعدة
LinkedIn: المهارات	صفحة المساعدة

الملحق المرجعي مرجع قابل للتحديث

ما يحتاج تحديثاً دورياً

المعلومة	متى تراجعها	الشرائح
رسوم الشهادات وتجديدها	كل 6 أشهر	الشريحتان 155 و156
مخططات الاختبارات ولغاتها	كل 6 أشهر، وقبل كل تسجيل	110 و117 و157 إلى 159
إصدارات الضوابط والأطر السعودية	كل 6 أشهر	95 و96 و160 و161
الإطار الوطني لإدارة المخاطر	عند أي تحديث من الهيئة	41 إلى 44
إصدارات ISO وNIST وPCI DSS	سنوياً	89 إلى 94
حدود لينكدإن ومساراته	سنوياً	137 و141
نظام حماية البيانات وجهة الإشراف	كل 6 أشهر	59